

Relatório de *Gap Analysis*

Gestão de Acessos Lógicos

BancoVotorantim

Versão 1.0 – Out.2015

TERMO DE CONFIDENCIALIDADE

Esse documento foi desenvolvido pela **SONDA IT** exclusivamente para a área de Segurança da Informação do **Banco Votorantim**. É vedada a sua reprodução parcial ou total, bem como sua distribuição a pessoas ou organizações estranhas às operações do **Banco Votorantim**, sem prévia autorização da alta direção da área de Segurança da Informação.

Controle do Documento

Cliente	**Banco Votorantim**
Título do Documento	**SONDA IT – Relatório de *Gap Analysis* GA – BV – v1.0 – 20151013**
Versão	1.0
Data da Publicação	13/10/2015
Autor	Jorge Maluf
Revisor	Eduardo Filho
Número de Páginas	83

Controle de Versão

Versão	Descrição	Autor	Data
0.1	Versão preliminar para análise do Coordenador de GA.	Jorge Maluf	28/09/2015
0.2	Versão revisada após considerações do Coordenador de GA.	Jorge Maluf	05/10/2015
1.0	Versão final para entrega.	Jorge Maluf	13/10/2015

Controle de Distribuição

Destinatário	Versão				
	0.1	0.2	-	-	1.0
Juliano Panciera					
Eduardo Guastella					
Leonardo Carmona					
Wagner Pugliese					

ÍNDICE

1 INTRODUÇÃO 5
1.1 Objetivo 6
1.2 Organização 7
1.3 Planejamento e Método 8
1.4 Roteiro e Calendário de Reuniões 9
2 CENÁRIO ATUAL SOBRE A CONFORMIDADE 12
3 CENÁRIO ATUAL SOBRE A QUALIDADE 17
3.1 Pessoas 18
3.1.1 N1 Sonda IT 19
3.1.2 N2 Sonda IT, N3 e Operações SI Banco Votorantim 22
3.2 Processo 26
3.2.1 Documentação 27
3.2.2 Indicadores 34
3.2.3 *SLAs* 37
3.2.4 LPG – Lista de Proprietários e Gestores dos Sistemas 38
3.3 Ferramentas 40
3.3.1 AD, VF ACESSO e IDM 40
3.3.2 CA *Service Desk* 41
3.4 Visão dos Negócios 43
3.5 Top 10 Ofensores 46
4 RECOMENDAÇÕES DE MELHORIAS 49
4.1 Fase da Estabilidade Operacional 52
4.2 Fase da Consolidação 57
4.3 Fase da Nova Imagem da Gestão de Acessos 65
4.4 Priorização das Recomendações 69
5 CONSIDERAÇÕES FINAIS 74
6 ANEXO A – MINI-CV DO TIME DO PROJETO 78
7 ANEXO B – GLOSSÁRIO 79

1 INTRODUÇÃO

O primeiro capítulo deste documento discorre essencialmente sobre:

- O objetivo do trabalho;
- A organização do relatório;
- O planejamento e o método de trabalho utilizados;
- O roteiro e calendário das reuniões com os principais interlocutores.

1.1 Objetivo

O objetivo desse trabalho foi oferecer aos executivos e líderes responsáveis pela área de Segurança da Informação do **Banco Votorantim**, um Relatório de *Gap Analysis* sobre o processo de Gestão de Acessos Lógicos, contendo uma visão imparcial a respeito do "Cenário Atual" (*As-Is*) do processo sob as perspectivas da CONFORMIDADE frente aos principais controles exigidos para este tema na Norma[1] ABNT ISO/IEC 27002:2013 e da QUALIDADE (Processos, Pessoas, Tecnologia) baseada em práticas reconhecidas de mercado, tais como ITIL e COBIT, além das "Recomendações de Melhorias" focadas em proporcionar melhorias efetivas na prestação de serviços aos clientes internos e usuários deste processo de gestão.

Nota[1]: Para fins deste relatório, foram utilizados os controles e objetivos de controle listados na Tabela A.1 do Anexo A da Norma ABNT ISO/IEC 27001:2013, os quais são derivados diretamente e estão alinhados com aqueles listados na Norma ABNT ISO/IEC 27002:2013.

1.2 Organização

A organização deste relatório prevê mais quatro capítulos, além deste introdutório, resumidamente descritos a seguir:

Capítulo 2 – Cenário Atual sobre a Conformidade

Apresenta uma análise dos principais controles relacionados ao processo de Gestão de Acessos Lógicos, descritos na Norma ABNT ISO/IEC 27002:2013, frente ao cenário atual estabelecido no **Banco Votorantim**.

Capítulo 3 – Cenário Atual sobre a Qualidade

Apresenta uma análise do cenário atual do processo de Gestão de Acessos Lógicos do **Banco Votorantim**, demonstrando as principais descobertas e informações mapeadas durante o trabalho e relacionadas às Pessoas (recursos humanos envolvidos na operacionalização do processo), Processo (documentações, regras e controles), Tecnologia (ferramentas utilizadas para a operacionalização do processo) e Visão dos Negócios (principais relatos obtidos durante as entrevistas com os clientes internos e usuários).

Capítulo 4 – Recomendações de Melhorias

Apresenta os pacotes de Recomendações de Melhorias direcionados à área de Segurança da Informação do **Banco Votorantim**, de forma a proporcionar melhorias efetivas na prestação de serviços aos clientes internos e usuários do processo de Gestão de Acessos Lógicos, bem como ampliar sua aderência aos controles da Norma ABNT ISO/IEC 27002:2013.

Capítulo 5 – Conclusões Finais

Apresenta as considerações finais do time de projeto sobre o cenário encontrado, análises efetuadas e visão de futuro baseada nas recomendações.

1.3 Planejamento e Método

O projeto de *Gap Analysis* que resultou na elaboração deste documento foi inicialmente planejado numa sequência de quatro etapas, são elas:

1. Planejamento e Início: reunião de *kick-off* e planejamento detalhado dos trabalhos;
2. Execução das Análises: realização das entrevistas e análises;
3. Elaboração do Relatório: elaboração do Relatório de *Gap Analysis;*
4. Apresentação dos Resultados: realização de uma apresentação final sobre os resultados aos executivos do **Banco Votorantim**.

Nosso método se baseou na condução e realização de entrevistas junto aos envolvidos na execução do processo e usuários-chave das áreas de negócios, na observação direta das práticas, na análise da documentação existente e outros instrumentos de controle, os quais nos permitiram realizar um mapeamento adequado e efetivo. A listagem completa das entrevistas está descrita no próximo tópico deste documento.

As análises realizadas sobre o processo de Gestão de Acessos Lógicos do **Banco Votorantim** procuraram diagnosticar, mas não se limitando a:

- Documentação existente sobre o processo;
- Ferramentas utilizadas para suporte ao processo;
- Indicadores existentes (*KPIs*) para gestão do processo;
- *SLAs* existentes (prazos de resolução de chamados) no processo;
- Percepção dos Clientes e Usuários sobre o processo;
- Conformidade do processo com a Norma ABNT ISO/IEC 27002:2013;
- Capacidades e limitações operacionais ou comportamentais dos envolvidos na execução do processo.

Posteriormente, foi realizado um estudo aprofundado, avaliando todo o conhecimento absorvido e insumos obtidos na Etapa II, para fins de elaboração deste Relatório de *Gap Analysis*.

1.4 Roteiro e Calendário de Reuniões

Com a finalidade de direcionar os trabalhos de análise e entendimentos sobre a situação atual do processo de Gestão de Acessos Lógicos do **Banco Votorantim**, foi elaborado um roteiro de principais interlocutores a serem entrevistados, sendo:

Cargo ou Função	Empresa	Objetivo
Coordenador de Gestão de Acessos	**Banco Votorantim**	Obter entendimentos gerais sobre a área de SI e GA, estrutura, histórico, ferramentas (oficiais e de apoio), analistas-chave, usuários-chave, expectativas, desafios futuros e pontos de melhorias já identificados.
Coordenador de Operações de SI	**Banco Votorantim**	Obter entendimentos gerais sobre a área de SI e GA, estrutura, histórico, ferramentas (oficiais e de apoio), recursos-chave, expectativas, desafios futuros e pontos de melhorias já identificados.
***Client Face* Sonda IT**	Sonda IT	Obter entendimentos sobre os desafios da Sonda IT relacionados ao serviço de Gestão de Acessos Lógicos. Conhecimento sobre os resultados das últimas reuniões com os executivos sobre o assunto.
Líder do N1	Sonda IT	Obter entendimentos sobre a estrutura do N1 e N2, recursos-chave, expectativas, desafios atuais, principais dificuldades e pontos de melhorias já identificados.
Líder do N2	Sonda IT	
Analistas-chave do N1	Sonda IT	Obter entendimentos e realizar observações sobre as práticas atualmente executadas, desafios atuais, principais dificuldades e pontos de melhorias já identificados.
Analistas-chave do N2	Sonda IT	
Analistas-chave do N3 e de Operações de SI	**Banco Votorantim**	
Usuários-chave dos Negócios	**Banco Votorantim**	Obter entendimentos sobre as necessidades, dificuldades, experiências e satisfação dos usuários-chave com os serviços prestados pela Gestão de Acessos Lógicos do **Banco Votorantim**.
Administrador da Ferramenta CA *Service Desk*	**Banco Votorantim**	Obter entendimentos sobre as principais restrições e funcionalidades da ferramenta CA *Service Desk*, utilizada para suporte e controle de chamados da Gestão de Acessos Lógicos do **Banco Votorantim**.
Gerente de Segurança da Informação	**Banco Votorantim**	Como principais *Sponsors* deste projeto, o objetivo da entrevista é obter entendimentos sobre as principais expectativas e eventuais direcionamentos estratégicos e táticos relacionados à Gestão de Acessos Lógicos do **Banco Votorantim**.
Information Security Officer	**Banco Votorantim**	

As principais reuniões e entrevistas realizadas ocorreram nas dependências do **Banco Votorantim** entre os dias 06 de julho e 28 de agosto de 2015, conforme detalhamento abaixo:

Data	Interlocutor	Cargo ou Função	Pauta Principal
06/07/15	**Eduardo Guastella e Juliano Panciera**	Gerente de Segurança da Informação e Coordenador do processo de Gestão de Acessos Lógicos	*Kick-Off* do Projeto.
12/07/15	**Juliano Panciera**	Coordenador do processo de Gestão de Acessos Lógicos	Estrutura, histórico, recursos e usuários-chave, ferramentas e principais desafios.
14/07/15	**Maurício Celentano**	*Cliente Face Sonda IT*	Histórico sobre atendimento à área de SI do **Banco Votorantim**.
17/07/15	**José Santiago**	Coordenador de Operações de SI	Estrutura da área, ferramentas de gestão de identidades e atendimento a chamados.
17/07/15	**Hugo Barros**	Líder N2	Estrutura do N2, principais analistas, rotinas e dificuldades.
22/07/15	**Dilma dos Santos Gomes**	Analista-Chave N2	Rotina operacional, dificuldades e motivação
23/07/15	**Wagner Pugliese**	Diretor Executivo **Banco Votorantim**	Status executivo sobre o projeto.
27/07/15	**Alexandre Brito**	Gerente do *Service Desk*	Histórico sobre atendimento à área de Gestão de Acessos Lógicos do BV.
28/07/15	**Joice Candido**	Líder N1	Estrutura do N1, principais analistas, rotinas e dificuldades.
29/07/15	**Isaías Santana da Silva**	Analista-Chave N2	Rotina operacional, dificuldades e motivação.
29/07/15	**Gilvânia Santos**	Analista-Chave N1	Rotina operacional, dificuldades e motivação.
31/07/15	**Klelder Mangieri**	Analista Operações SI	Rotina operacional, dificuldades e motivação.
04/08/15	**Lucimara Maçorano**	Usuária-Chave do SAC (Atendimento)	Principais necessidades, dificuldades e satisfação sobre o processo de Gestão de Acessos Lógicos.
06/08/15	**Danilo Caetano**	Analista-Chave N2 / N3	Rotina operacional, dificuldades e motivação.

Data	Interlocutor	Cargo ou Função	Pauta Principal
11/08/15	**Renata Alcântara e Letícia Santos representando Cássia Nunes**	Usuárias-Chave da Cobrança	Principais necessidades, dificuldades e satisfação sobre o processo de Gestão de Acessos Lógicos.
12/08/15	**Alethea Santos e Ana Brito**	Usuárias-Chave do Jurídico	Principais necessidades, dificuldades e satisfação sobre o processo de Gestão de Acessos Lógicos.
17/08/15	**Wilton Almeida, Monica Leite, Cícera Terto e Vanessa Nelo**	Usuários-Chave do Cadastro, Desaverbação, Recebimentos e Inadimplência	Principais necessidades, dificuldades e satisfação sobre o processo de Gestão de Acessos Lógicos.
17/08/15	**Camila Sato**	Usuária-Chave do Suporte Comercial do Varejo	Principais necessidades, dificuldades e satisfação sobre o processo de Gestão de Acessos Lógicos.
18/08/15	**Flora Lira**	Usuária-Chave do SAC (Atendimento)	Principais necessidades, dificuldades e satisfação sobre o processo de Gestão de Acessos Lógicos.
20/08/15	**Leonardo Carmona e Eduardo Guastella**	*Information Security Officer* e Gerente de Segurança da Informação	Principais dificuldade e necessidades imediatas na visão gerencial.
21/08/15	**Allan Buscarino**	Especialista Gestão de Acessos	Histórico Payware x HP.
25/08/15	**Fernanda Daré**	Especialista Gestão de Acessos	*RBAC* e Workflow via IDM.
26/08/15	**Thiago Querino e José Eduardo**	Administrador da ferramenta CA *Service Desk* e Especialista TI-Sistemas	Iniciativa de revisão do Catálogo de Serviços que TI-Sistemas já está executando e funcionalidades da ferramenta CA *Service Desk*.
28/08/15	**Wagner Puglise**	Diretor Executivo **Banco Votorantim**	Status Executivo sobre o projeto.

2 CENÁRIO ATUAL SOBRE A CONFORMIDADE

A seguir, apresentamos o cenário atual (*As-Is*) do processo de Gestão de Acessos Lógicos sob a perspectiva da **CONFORMIDADE**, demonstrando nossa análise sobre os controles principais da **Seção 9 (nove) – "Controle de Acesso"** da Norma ABNT ISO/IEC 27002:2013:

Referência	Descrição	Controle	Análise Crítica
A.9.1 Requisitos de negócio para controle de acesso **Objetivo:** *Limitar o acesso à informação e aos recursos de processamento da informação.*			
A.9.1.1	Política de controle de acesso	Convém que a política de controle de acesso seja estabelecida documentada e analisada criticamente, tomando-se como base os requisitos de acesso dos negócios e segurança da informação.	Identificamos documentos normativos oficialmente publicados que, em conjunto, estabelecem a política e as diretrizes fundamentais para o controle de acesso lógico do **Banco Votorantim**, a saber: • **MNO_025** (Norma de Proprietários e Gestores dos Sistemas de Informação): determina os papéis dos proprietários das informações, gestores dos sistemas e elaboração/manutenção da LPG - Lista de Proprietários e Gestores dos Sistemas. • **MNO_253** (Norma de Concessão e Revisão de Acessos a Sistemas, Diretórios de Rede, Banco de Dados e AD): determina o formato de solicitação e autorização formal de pedidos de acesso e principalmente pela administração de acesso (concessão, revogação e revisão). • **MPR_1341** (Procedimento de Revisão de Acesso a Sistemas e Bancos de Dados): descreve o procedimento operacional para revisão de acessos a sistemas e bancos de dados. • **MPR_1394** (Procedimento e Fluxo de Gestão de Acesso de Sistemas e Banco de Dados): descreve o procedimento operacional para concessão e revogação de acessos a sistemas e bancos de dados.
A.9.1.2	Acesso às redes e aos serviços de rede	Convém que os usuários somente recebam acesso as redes e aos serviços de rede que tenham sido especificamente autorizados a usar.	Identificamos documentos normativos oficialmente publicados que, em conjunto, estabelecem as diretrizes para acesso e monitoramento das redes e serviços de rede do **Banco Votorantim**, a saber: • **MNO_253** (Norma de Concessão e Revisão de Acessos a Sistemas, Diretórios de Rede, Banco de Dados e AD): determina o formato de solicitação e autorização formal, revogação e revisão de acesso aos Diretórios de Rede, considerados "serviços de rede", sob a perspectiva da ISO27002:2013. • **MNO_007** (Norma de Utilização de Recursos Corporativos - *Communicator* e Internet): determina o formato de solicitação e autorização formal de exceções de acesso e também monitoramento de uso da Internet e do *Communicator*, considerados "serviços de rede", sob a perspectiva da ISO27002:2013. • **MNO_066** (Norma de Utilização de Correio Eletrônico): determina os padrões de uso do Correio Eletrônico e as regras para liberação e monitoração do acesso remoto ao

Referência	Descrição	Controle	Análise Crítica
			mesmo, considerado um "serviço de rede", sob a perspectiva da ISO27002:2013. • **MNO_067** (Norma de Acesso Remoto aos Computadores Corporativos): determina os critérios de elegibilidade, formato de solicitação e autorização formal, requisitos de autenticação e monitoramento do Acesso Remoto aos Computadores Corporativos, considerado um "serviço de rede", sob a perspectiva da ISO27002:2013. • **MNO_401** (Norma de Utilização da Rede Corporativa Wireless): determina o formato de solicitação, autorização formal, requisitos de autenticação/criptografia e monitoramento do acesso às Redes Corporativas *Wireless* - incluindo a rede wireless para "visitantes".
A.9.2 Gerenciamento de acesso de usuário **Objetivo:** *Assegurar o acesso de usuário autorizado e prevenir o acesso não autorizado aos sistemas e serviços.*			
A.9.2.1	Registro e cancelamento de usuário	Convém que exista um procedimento formal de registro e cancelamento de usuário para permitir atribuição dos direitos de acesso.	Identificamos um documento normativo oficialmente publicado que estabelece a formalização de registro e cancelamento de usuários no **Banco Votorantim**, a saber: • **MNO_315** (Criação e Desativação de *Login* de Rede, Contas e Grupos de E-mail): determina a criação do *Login* de rede, principal identificador único (ID) dos usuários no **Banco Votorantim**, e inclui regras para desativação deste ID mediante comunicação da área de Recursos Humanos sobre o desligamento do colaborador ou por solicitação direta do gestor imediato, Auditoria Interna, *Compliance* ou Inspetoria.
A.9.2.2	Provisionamento para acesso de usuário	Convém que um processo formal de provisionamento de acesso do usuário deve ser implementado para conceder ou revogar os direitos de acesso para todos os tipos de usuários em todos os tipos de sistemas e serviços.	Identificamos um documento normativo oficialmente publicado que estabelece o processo de provisionamento de acesso (concessão, revogação e revisão) aos usuários no **Banco Votorantim**, a saber: • **MNO_253** (Norma de Concessão e Revisão de Acessos a Sistemas, Diretórios de Rede, Banco de Dados e AD): determina as regras para **concessão de acessos** (solicitação e autorização/aprovação formal do proprietário da informação e do gestor imediato do solicitante), **revogação de acessos** (em caso de transferência de área ou função, comunicação da área de Recursos Humanos sobre desligamento ou por solicitação direta do gestor imediato, gestor do sistema, proprietário da informação, Auditoria Interna, *Compliance* ou Inspetoria) e **revisão de acessos** (pontual ou anual) de **todos os sistemas de informação e para todo os tipos de usuários**, sejam usuários nominais, usuários de serviço ou grupos de usuários.

Referência	Descrição	Controle	Análise Crítica
A.9.2.3	Gerenciamento de direitos de acesso privilegiado	Convém que a concessão e uso de direitos de acesso privilegiado sejam restritos e controlados.	Identificamos um documento normativo oficialmente publicado que estabelece as regras para padronização e regulamentação de uso das contas com privilégios administrativos e contas de serviço no **Banco Votorantim**, a saber: • **MNO_672** (Utilização de Contas com Privilégios Administrativos ou de Serviço): determina as regras para **concessão de acessos administrativos e de serviços** através de um procedimento de autorização formal mais rígido (obrigatoriedade de aprovação do Superintendente do solicitante e também de Segurança da Informação), da exigência de um *Login* secundário armazenado no sistema "Cofre de Senhas" e principalmente pela descrição das responsabilidades, critérios de uso e sanções aos administradores de sistemas, bancos de dados e infraestrutura que possuírem este tipo de acesso para execução de suas atividades.
A.9.2.4	Gerenciamento da informação de autenticação secreta de usuários	Convém que a concessão de informação de autenticação secreta seja controlada por meio de um processo de gerenciamento formal.	Identificamos um documento normativo oficialmente publicado que estabelece a formalização do processo de controle das informações de autenticação secreta no **Banco Votorantim**, a saber: • **MNO_332** (Senhas nos Sistemas de Informação): determina as regras e padrões relacionados à posse e uso de senhas tais como: critérios de formação, expiração por tempo, identificação positiva do usuário ante o fornecimento da senha, alteração no primeiro acesso, diversificação, bloqueio por falhas consecutivas, entre outros aspectos.
A.9.2.5	Análise crítica dos direitos de acesso do usuário	Convém que os proprietários de ativos analisem criticamente os direitos e acesso dos usuários a intervalos regulares.	Identificamos um documento normativo oficialmente publicado que estabelece a formalização do processo de revisão de acessos lógicos no **Banco Votorantim**, a saber: • **MNO_253** (Norma de Concessão e Revisão de Acessos a Sistemas, Diretórios de Rede, Banco de Dados e AD): determina as regras e padrões relacionados à revisão de acessos lógicos tais como: análise crítica pelos proprietários das informações/sistemas, revisão pontual por transferência de função, revisão obrigatória anual, escopo das revisões (usuários nominais e privilegiados).
A.9.2.6	Retirada ou ajuste dos direitos de acesso	Convém que os direitos de acesso de todos os funcionários e partes externas às informações devem ser retirados após o encerramento de suas atividades, contratos ou acordos, ou ajustado após a mudança destas atividades.	Identificamos um documento normativo oficialmente publicado que estabelece a formalização do processo de revogação de acessos lógicos no **Banco Votorantim**, a saber: • **MNO_253** (Norma de Concessão e Revisão de Acessos a Sistemas, Diretórios de Rede, Banco de Dados e AD): determina os eventos que originam as revogações de acessos lógicos tais como: comunicação da área de Recursos Humanos sobre o desligamento do colaborador ou solicitação direta do gestor imediato, Auditoria Interna, *Compliance* ou Inspetoria.

Referência	Descrição	Controle	Análise Crítica
A.9.3 Responsabilidades dos usuários **Objetivo:** *Tornar os usuários responsáveis pela proteção das suas informações de autenticação.*			
A.9.3.1	Uso da informação de autenticação secreta	Convém que os usuários sejam orientados a seguir as práticas da organização quanto ao uso da informação de autenticação secreta.	Identificamos um documento normativo oficialmente publicado que estabelece as responsabilidades dos colaboradores pelo uso de senhas no **Banco Votorantim**, a saber: • **MNO_332** (Senhas nos Sistemas de Informação): determina as responsabilidades dos colaboradores pelo uso e manutenção de suas senhas (informação de autenticação secreta), como a proibição de compartilhamento e critérios de formação (tamanho mínimo, expiração, complexidade). Também orienta os usuários a não utilizarem senhas iguais ao "*Login*", sobrenome, nomes de parentes ou qualquer outro contexto de fácil relação com o usuário).
A.9.4 Controle de acesso ao sistema e à aplicação **Objetivo:** Prevenir a acesso não autorizado aos sistemas aplicações.			
A.9.4.1	Restrição de acesso à informação	Convém que o acesso a informações e às funções dos sistemas de aplicação seja restrito de acordo com a política de controle de acesso.	Identificamos documentos normativos oficialmente publicados que estabelecem, em conjunto, a exigência de restrições de acesso aos sistemas aplicativos do **Banco Votorantim**, a saber: • **MNO_671** (Segregação de Funções de Segurança da Informação): determina que os sistemas aplicativos devem ser estruturados sob o princípio de segregação de funções, prevendo a separação de funcionalidades conflitantes de acordo com as necessidades dos negócios e de forma que nenhum colaborador detenha competências e atribuições que caracterizem excesso de privilégios. • **MNO_675** (Segurança no Desenvolvimento, Aquisição e Manutenção de Sistemas): determina que todos os sistemas possuam documentação formal de suas transações e perfis de acesso (cada perfil com suas respectivas funcionalidades, privilégios e alçadas).
A.9.4.2	Procedimentos seguros de entrada no sistema *(log-on)*	Convém que onde aplicável pela política de controle de acesso, o acesso aos sistemas e aplicações sejam controlados por um procedimento seguro de entrada no sistema (*log-on*).	Identificamos um documento normativo oficialmente publicado que estabelece de controle de entrada (*log-on*) e trilhas de auditoria nos sistemas do **Banco Votorantim**, a saber: • **MNO_675** (Segurança no Desenvolvimento, Aquisição e Manutenção de Sistemas): determina o padrão de trilhas de auditoria de gestão de identidades e acessos (usuário, data e hora, endereço IP de origem do acesso, ação executada no sistema como *log-on*), incluindo seu período de retenção mínima de 5 (cinco) anos. Além disso, determina a obrigatoriedade de utilização de mecanismos de autenticação e autorização de acesso aos sistemas. Identificamos a utilização de "*tokens*" para acesso aos sistemas críticos (tecnologia em processo de substituição do modelo físico para um aplicativo mobile que funcionará como "*token*").
A.9.4.3	Sistema de gerenciamento de senha	Convém que os sistemas de gerenciamento de senhas sejam	Em contato com os responsáveis pela área de Gestão de Acessos do **Banco Votorantim** e também analistas-chave de N2, fomos informados que todos os sistemas integrados com as bases de dados de usuários oficiais, como o *AD* –

Referência	Descrição	Controle	Análise Crítica
		interativos e assegurem senhas de qualidade.	*Active Directory*, respeitam a política de Senhas **MNO_332** (Senhas dos Sistemas de Informação). Já para os sistemas não integrados, é mandatório que as regras descritas nesta norma sejam aplicadas, salvo por restrição da tecnologia ou arquitetura sistêmica, devendo ser realizado acionamento da Segurança da Informação, a qual procederá uma avaliação sobre o caso.
A.9.4.4	Uso de programas utilitários privilegiados	Convém que o uso de programas utilitários que podem ser capazes de sobrepor os controles dos sistemas e aplicações sejam restritos e estritamente controlado.	A utilização de programas utilitários, como por exemplo o "*Remote Desktop*", para acesso a computadores ou sistemas de informação está coberta pelas normas **MNO_067** (Acesso Remoto aos Computadores Corporativos) e **MNO_672** (Utilização de Contas com Privilégios Administrativos ou de Serviço), que determinam suas regras de utilização, responsabilidades, sanções e procedimentos formais de autorização, controle e monitoramento.
A.9.4.5	Controle de acesso ao código-fonte de programas	O acesso ao código-fonte de programa deve ser restrito.	Identificamos um documento normativo oficialmente publicado que estabelece a restrição de acesso aos códigos-fonte dos sistemas no **Banco Votorantim**, a saber: • **MNO_675** (Segurança no Desenvolvimento, Aquisição e Manutenção de Sistemas): determina em sua cláusula 1.2.4 a restrição de acessos aos códigos-fonte e demais itens associados ao desenvolvimento de sistemas como desenhos técnicos e especificações.

3 CENÁRIO ATUAL SOBRE A QUALIDADE

Nos tópicos a seguir, apresentamos o cenário atual (*As-Is*) do processo de Gestão de Acessos Lógicos sob a perspectiva da **QUALIDADE** referente à prestação deste serviço aos clientes internos e usuários do **Banco Votorantim**, demonstrando nossos principais levantamentos e informações sobre:

- Pessoas: recursos humanos envolvidos na operacionalização do processo;
- Processo: documentações, regras e controles estabelecidos;
- Tecnologia: ferramentas utilizadas para operacionalização do processo;
- Visão dos Negócios: principais relatos obtidos durante as entrevistas com os clientes internos e usuários.

3.1 Pessoas

Neste tópico, abordamos os analistas-chave na operacionalização do processo de Gestão de Acessos Lógicos, os quais foram indicados pelas lideranças da área, e buscamos entender quais eram suas rotinas, ferramentas e instrumentos utilizados, histórico de trabalho no tema e na área, capacitação e treinamentos, incluindo o suporte gerencial e motivacional que obtinham. Também buscamos entender sua visão de futuro e eventuais melhorias já mapeadas.

3.1.1 N1 Sonda IT

Tivemos contato e observamos *in-loco* o trabalho da analista-chave Gilvânia Santos, a qual representou a equipe de atendimento do *Service Desk* N1 da Sonda IT. Nossa interlocução com esta analista foi indicada pela líder de N1, Joice Candido, pois Gilvânia atua nesta operação desde o início e hoje já é considerada a ponto focal para toda a equipe de N1 que atende a área de SI do **Banco Votorantim**.

A analista-chave nos esclareceu os principais desafios associados ao atendimento do processo de Gestão de Acessos Lógicos do **Banco Votorantim**, tendo em vista:

- **Dificuldade dos usuários em saber quais perfis e sistemas realmente precisam solicitar**, isto demanda dos analistas de atendimento a necessidade de solicitar *prints* de tela e também perfis "espelho" aos usuários para que possam endereçar a abertura dos chamados de acesso.

- **Grande quantidade de sistemas e siglas** que o **Banco Votorantim** possui, representando um fator de grande complexidade de entendimento aos analistas, principalmente aos mais novos.
    - Os usuários de negócios estão acostumados "a falar a linguagem específica do banco", como as siglas que identificam os sistemas utilizados e que muitas vezes não é compreendida de imediato pelos analistas, como por exemplo, o "PTA" que não representa apenas um único sistema, mas uma série de "sub-sistemas" ou "módulos" de sistemas.
    - Sabemos que existe uma "curva (tempo) inicial de aprendizado" que é natural a qualquer profissional que inicie seu trabalho numa célula de atendimento, porém, a grande quantidade de sistemas e siglas acaba dificultando ou adiando um pouco este cenário.

- **Dificuldade dos analistas de atendimento em encontrar a categoria mais adequada para abertura do chamado devido à grande quantidade de opções** na ferramenta.

- A categorização (Catálogo) que existe atualmente na ferramenta CA *Service Desk* para abertura de chamados foi tombada "*As-Is*" da ferramenta anterior. Obtivemos o seguinte exemplo de categorias que podem confundir os analistas durante a abertura dos chamados: "*SAS – Atendimento Solicitações", "SAS – Guide", "SAS (Crédito)", "SAS – Estatística e Analise (BCO)", "SAS – Estatística e Análise (Financeira)"*.

- **Necessidade de apontar manualmente o gestor de acesso (dono ou responsável pelo sistema/perfil)** no fluxo de aprovações da ferramenta, o que aumenta a probabilidade de erro operacional (humano) ou até o apontamento correto, mas não efetivo, em dois casos: quando eventualmente a LPG (Lista de Proprietários e Gestores dos Sistemas) esteja desatualizada para aquele determinado sistema ou quando o Gestor de Acesso está em período de férias. No último caso, os chamados permanecem no status "Pendente Aprovação" e acabam sendo encerrados por falta de aprovação, o que deixa os usuários ainda mais insatisfeitos e gera consultas sobre o andamento dos mesmos.

- **Necessidade de efetuar cobranças dos chamados "Pendente Cliente"** o que demanda um tempo grande de alguns analistas do atendimento, em detrimento ao atendimento telefônico e resolução de chamados em N1.
  - A analista-chave comentou que seria muito produtivo se a ferramenta realizasse automaticamente, por e-mail, a cobrança dos chamados neste status, assim como já ocorre aos aprovadores durante os fluxos de aprovações.

- **Necessidade de mais treinamentos e reciclagem periódica sobre a "linguagem comum" (principais siglas e sistemas) e também sobre os novos processos implantados, como por exemplo o *RBAC*.**
  - Sobre o *RBAC*, foi solicitado ao Juliano Panciera e Fernanda Daré que realizassem um treinamento específico aos analistas de atendimento N1, tendo em vista as dúvidas dos mesmos. Este treinamento ocorreu em 07 de agosto de 2015.

- Sobre a reciclagem quanto à linguagem "comum" utilizada pelos usuários referente aos principais sistemas, siglas e perfis, Gilvânia nos informou que ocorreu uma única vez, ministrado pelo especialista Allan Buscarino, pouco tempo antes da equipe iniciar efetivamente o atendimento aos usuários.

Durante o acompanhamento da rotina do N1, fomos informados sobre a **melhoria de produtividade proporcionada pela automatização das atividades de "*Reset* de Senha de Rede" e "Consulta de Chamados" via URA**.

Joice (Líder N1) nos demonstrou que a quantidade de ligações oferecidas obteve significativa redução após a implantação destas funcionalidades, o que permitiu direcionar os analistas para a resolução de chamados (*Backlog*).

Questionada sobre a existência de Instruções de Trabalho e orientações aos analistas de atendimento, Joice nos apresentou a **Base de Conhecimentos mantida na ferramenta CA *Service Desk*** e alimentada com informações, regras e direcionamentos passados pela liderança e especialistas do processo de Gestão de Acessos Lógicos do **Banco Votorantim**.

3.1.2 N2 Sonda IT, N3 e Operações SI Banco Votorantim

Tivemos contato e observamos *in-loco* o trabalho dos analistas-chave de N2 e N3 que foram indicados pelo Coordenador de Gestão de Acessos Lógicos (Juliano Panciera) – vide tópico 1.4 deste documento. De forma geral, pudemos perceber algumas características comuns aos mesmos, tais como:

- **Grande comprometimento** com o resultado de seu trabalho, onde todos demonstraram o esforço e a complexidade de suas atividades, relatando compreenderem as urgências dos usuários pelos acessos.

- **Bons conhecimentos técnicos** devido a experiência acumulada pelo tempo de "casa", em média mais de 4 (quatro) anos prestando serviços ao **Banco Votorantim** e em atividades relacionadas ao processo de Gestão de Acessos Lógicos.

- **Entendimentos sobre as principais dificuldades** relacionadas às suas atividades específicas, tais como atraso gerado na solução dos chamados e que se origina no desconhecimento dos próprios usuários em relação aos perfis e sistemas que realmente necessitam acessar.
    - Este fato acaba demandando tempo adicional dos analistas que precisam analisar cada perfil "espelho" e "*print*" de tela informados na abertura dos chamados, para poderem entender efetivamente as necessidades dos usuários, isto quando não acabam entrando em contato diretamente com os mesmos para conseguirem tais informações.

- **Pró atividade na identificação de desvios e falhas**, endereçando as mesmas para correção pelos responsáveis.

- **Grande vontade de colaborar e prontidão a atender outras demandas** oriundas diretamente de seus colegas, dos usuários ou até das próprias lideranças da área de Segurança da Informação.

- Essa característica foi observada muito fortemente no analista Danilo Caetano, que se tornou ponto focal para dúvidas pelo time de N1 e por alguns usuários-chave, sendo reconhecido como um colaborador que auxilia a todos quando necessário.
- Há um viés positivo pela boa vontade e colaboração, mas por outro lado acaba tomando tempo em detrimento ao atendimento de chamados dos usuários.
- Outro ponto negativo que essa característica pode acarretar é que a aproximação com os usuários de negócios pode originar a alguma solicitação diretamente aos analistas, seja por telefone, *Communicator* ou até ainda pessoalmente, negligenciando as regras e controles do processo.

- **Ciência sobre sua importância na área** relacionada ao fato dos conhecimentos técnicos estarem centralizados nos mesmos, tornando o **Banco Votorantim** e a própria Sonda IT, de certa forma, dependentes de sua atuação.

- **Desconforto e certo descrédito sobre "melhorias efetivas" em seu dia-a-dia de trabalho**, onde foram citados alguns casos emblemáticos como:
  - O *tombamento da Gestão de Acessos do Payware da HP para o BV*, que iria reduzir drasticamente os tempos de atendimento desses chamados e tomava mais de 30% do tempo na analista Dilma, em cobranças diárias para que a HP efetivasse a liberação dos acessos aos usuários do BV e também a *passagem da Manutenção de Alçadas no ERP para a área de Contas a Pagar*, atividade que deveria ser desta área por padrão, mas que tomava mais de 50% do tempo de trabalho do analista Isaías – além da exposição do próprio analista caso realizasse alguma alteração de alçada equivocada ou indevida, a qual poderia acarretar danos ou até permitir atividades fraudulentas por parte de algum usuário mal-intencionado.
    - Estas atividades foram relatadas com algum desconforto pelos analistas envolvidos, os quais estavam sendo cobrados pela sua produtividade em relação ao atendimento de chamados, mas que utilizavam grande parte do tempo na realização das mesmas.

- Além disso, identificamos que as duas iniciativas já vinham sendo trabalhadas há mais de dois meses, sem previsão de conclusão, o que frustrava ainda mais os analistas, onde obtivemos relatos como o seguinte: "*... não tenho muita esperança que as coisas vão melhorar... muito já se prometeu e não mudou. Apenas aceitei a situação e continuo fazendo o melhor que posso pelos usuários do Banco*".

Com relação aos instrumentos e ferramentas de apoio utilizados para realização do seu trabalho, os analistas nos informaram:

- A ferramenta CA *Service Desk*;
- As ferramentas VF Acesso, *AD* e IDM;
- A LPG (Lista de Proprietários e Gestores dos Sistemas);
- Pequena parcela de documentos oficiais (normas ou procedimentos);
- Seus próprios documentos ou anotações;
- A grande utilização de e-mails contendo cobrança de priorizações, cobrança de status, solicitações diversas e *inputs* para realização de outras atividades, como por exemplo, a atualização da LPG.

Com base no relato dos analistas que acabam utilizando poucos documentos oficiais e em maior parte seus próprios documentos e anotações, averiguamos a **ausência de Instruções de Trabalho para os analistas de N2 e N3** (as Instruções de Trabalho são documentos técnicos contendo o passo-a-passo para realização de determinadas atividades).

Um fato relevante sobre este assunto e que merece o devido destaque foi a iniciativa individual do analista Klélder (equipe de Operações de SI), o qual **documentou todas as atividades que estava repassando ao analista Nicolas (N2) em formato de Instruções de Trabalho** e com grande riqueza de detalhes, como *prints* de tela, indicações por seta e roteiro de passos a serem seguidos. Esta iniciativa deve ser utilizada como **exemplo a ser seguido para documentar os conhecimentos que atualmente estão centralizados nos analistas-chave**, conforme já mencionado.

Sobre capacitação e reciclagem de conhecimentos, os analistas-chave entrevistados mencionaram que **nunca houve uma periodicidade definida** e que os treinamentos aos quais já participaram até hoje, ocorreram de forma pontual mediante a implantação de novos sistemas ou controles. Em algumas oportunidades, um dos analistas acabava sendo eleito como "multiplicador", para comparecer ao treinamento e posteriormente repassar o conhecimento obtido aos colegas, o que nem sempre ocorria pelo foco no dia-a-dia operacional da área.

3.2 Processo

A Gestão de Acessos Lógicos do **Banco Votorantim** **possui seus processos primários de Concessão, Revogação e Revisão de acessos oficializados e formalmente documentados** em Normativas e Procedimentos publicados em seu repositório oficial de documentação na intranet, tais como:

- **MNO_025** (Norma de Proprietários e Gestores dos Sistemas de Informação);
- **MNO_253** (Norma de Concessão e Revisão de Acessos a Sistemas, Diretórios de Rede, Banco de Dados e AD);
- **MPR_1341** (Procedimento de Revisão de Acesso a Sistemas e Bancos de Dados);
- **MPR_1394** (Procedimento e Fluxo de Gestão de Acesso de Sistemas e Banco de Dados).

A análise de Processo se baseou em documentos indicados pelo coordenador da área, incluindo outros que selecionamos diretamente no repositório oficial de documentação e que possuíam relacionamento com a Gestão de Acessos (ex.: documentos da área de Tecnologia / Sistemas).

Além disso, analisamos algumas regras e controles estabelecidos, tais como *SLAs* existentes e já parametrizados em ferramenta, Indicadores produzidos e divulgados à alta gestão da área de SI e LPG (Lista de Proprietários e Gestores dos Sistemas).

3.2.1 Documentação

A seguir, apresentamos uma análise detalhada sobre cada documento oficial do processo de Gestão de Acessos Lógicos do **Banco Votorantim,** além de outros que possuem relacionamento direto com o tema.

ID	Nome do Documento	Versão	Última Atualização	Análise do Documento
MPR_1394	Procedimento e Fluxo de Gestão de Acesso de Sistemas e Banco de Dados	2.0	12/01/15	• Refere-se ao procedimento e fluxo do principal processo da área: Gestão de Acessos de Sistemas e Bancos de Dados. • Convém promover um *workshop* ou treinamento periódico para todos os analistas que atuam em Gestão de Acessos para reciclagem de conhecimentos.
MNO_672	Norma de Utilização de Contas com Privilégios Administrativos ou de Serviço	8.0	16/10/14	• Refere-se a um dos principais documentos normativos da Gestão de Acessos Lógicos, estabelecendo as diretrizes e regras para utilização de contas de serviço ou com privilégios administrativos. • Por se tratar de liberação de acessos privilegiados, convém reforçar a todos os envolvidos no processo, as cláusulas 1.1.2, 1.1.7, 1.2.3, 1.2.4, 1.2.6 e 1.2.7, 2.3.5, 2.3.12 que versam sobre as responsabilidades dos aprovadores e os níveis de aprovação necessários para obtenção deste tipo de acesso. • Correção: alterar o termo "minhas" por "suas" nas cláusulas 1.1.9 e 2.3.1. • Correção: alterar no Glossário o nome da ferramenta de chamados "ASK" (descontinuada) para "CA Service Desk" (atual). • Convém especificar claramente a periodicidade da revisão detalhada de todos os acessos privilegiados e contas de serviço, incluindo a avaliação das funções dos colaboradores que os possuem, identificando a necessidade de permanência. • Convém que passe a ser exigido como pré-requisito para a abertura de chamados de solicitação de acesso privilegiado, um Termo de Responsabilidade assinado pelo solicitante e que identifique sua ciência sobre as cláusulas da Norma MNO_672 reforçando suas responsabilidades e possíveis sanções em caso de descumprimento ou violação. • Convém promover uma revisão e atualização do documento mediante necessidades de correção e inclusão da cláusula que solicita a assinatura do Termo de Responsabilidade.

ID	Nome do Documento	Versão	Última Atualização	Análise do Documento
MNO_253	Norma de Concessão e Revisão de Acessos a Sistemas, Diretórios de Rede, Banco de Dados e AD	17.0	03/07/15	• Refere-se a um dos principais documentos normativos da Gestão de Acessos Lógicos, estabelecendo as diretrizes e regras para concessão, revogação e revisão de acessos a todos os Sistemas (mesmo que a gestão de acessos seja realizada por outra área), Diretórios de Rede, Bancos de Dados e *Active Directory*. • Convém reforçar as cláusulas 2.1.10, 3.1.13, 4.1.7, 4.1.13 que estabelecem aos gestores cedentes, a obrigatoriedade de desativação dos acessos de um colaborador transferido para outra área.
MNO_072	Norma de Gestão de Mudanças	18.0	22/06/15	• Área de Segurança da Informação é envolvida como aprovadora obrigatória de GMUDs relacionadas à infraestrutura, efetuando análises de risco para manter os níveis de segurança dos processos da empresa (cláusula 5.2.1.d). • Convém que seja discutido com os responsáveis pelo processo de Gestão de Mudanças a inclusão de um especialista de Gestão de Acessos como aprovador da implantação de novos sistemas ou de alterações significativas em sistemas já implantados, de forma a resguardar os requerimentos de Gestão de Acessos, tais como criação de perfis e treinamento dos analistas de Gestão de Acessos para suportar as solicitações relacionadas ao sistema em questão.
MNO_071	Norma de Segurança nas Estações de Trabalho - Permissões de Acessos e Gravação de Informações	10.0	08/06/15	• A Cláusula 1.1.2 deve ser reforçada a todos os colaboradores do BV, pois informa a proibição do compartilhamento de senhas. Durante as entrevistas com os usuários-chave, fomos informados sobre a ocorrência desta prática quando um chamado de acesso demora a ser atendido, o que implica uma falta grave pelos colaboradores que estão realizando este procedimento.
MNO_025	Norma de Proprietários e Gestores dos Sistemas de Informação	10.0	26/09/14	• Informa que a atualização da LPG deveria ser feita pela área de Operações de SI, e atualmente é realizada pelos analistas de N2 da Gestão de Acessos. • Após presenciarmos uma situação em que houve dificuldade para identificação do proprietário de um diretório de rede, se faz necessário reforçar a todos os proprietários de diretórios de rede, as cláusulas 3.1.4 e 3.1.5 desta norma, as quais os responsabilizam (bem como seus superiores imediatos) a atualizarem estas informações junto à área de SI. • Convém promover uma revisão e atualização do documento mediante ajuste sobre a área que efetivamente mantém a LPG atualmente.
MNO_332	Norma de Senhas dos Sistemas de Informação	11.0	23/02/15	• A Cláusula 1.1.2 deve ser reforçada a todos os colaboradores do BV, pois informa a proibição do compartilhamento de senha individual. Durante as entrevistas com os usuários-chave, fomos informados sobre a ocorrência desta prática quando um chamado de acesso demora a ser atendido, o que implica uma falta grave pelos

ID	Nome do Documento	Versão	Última Atualização	Análise do Documento
				colaboradores que estão realizando este procedimento. • Após a automatização do *Reset* e Desbloqueio de Senha de Rede via URA, convém atualizar a cláusula 2.2.1 que versa sobre as formas de desbloquear o usuário.
MNO_315	Norma de Criação e Desativação de *Login* de Rede, Contas e Grupos de E-mail	13.0	11/05/15	• Refere-se a um dos principais documentos normativos da Gestão de Acessos Lógicos, estabelecendo as diretrizes e regras para Criação, Desativação de *Logins* de Rede, Contas de E-mail e Grupos de E-mail. • Convém reforçar aos gestores que possuam colaboradores terceiros, a cláusula 1.1.6 que versa sobre a obrigatoriedade da desativação da conta do terceiro em caso de rompimento do contrato ou desligamento do colaborador terceiro antes do período máximo de 90 (noventa) dias em que a conta permanece válida. • Foi observada durante a análise, a existência de um enorme volume de Grupos de Distribuição utilizados pelo **Banco Votorantim** e suas empresas. Uma vez que as cláusulas 3.3.2.c e 3.4.4 versam sobre a responsabilidade da área de Governança de Segurança da Informação em avaliar a real necessidade de utilização do usuário sobre este recurso, pode ser conveniente que esta mesma área promova uma campanha interna para que as áreas usuárias revisem a quantidade de grupos que utilizam, tendo em vista que a enorme quantidade de grupos existentes inevitavelmente confunde os usuários para abertura de chamados de acesso (inclusão nos grupos). Isto pode ser facilmente observado, tendo em vista que a categoria de chamado GRUPO DE EMAIL.INCLUIR USUARIO é a "Top 15" ofensora de chamados na Gestão de Acessos.
MNO_248	Norma de Operacionalização do Celular Corporativo	11.0	12/01/15	• Nenhuma informação relevante relacionada especificamente à Gestão de Acessos Lógicos. Todas as tratativas de chamados sobre celulares corporativos são direcionadas ao *Service Desk* de TI.
MNO_007	Norma de Utilização de Recursos Corporativos - *Communicator* e Internet	6.0	12/09/14	• A análise deste documento foi realizada devido à categoria de chamados SOFTWARE.MICROSOFT. *COMMUNICATOR*.LIBERAR ACESSO ser a "Top 11" ofensora de chamados na Gestão de Acessos. Com base na cláusula 3.1.1, o acesso ao sistema de mensagens internas *Communicator* é "liberado para todos os colaboradores salvo por definição da área com comunicação prévia à área Recursos Humanos". Com base nessa informação, convém que sejam analisados em detalhes os chamados desta categoria, visto que o acesso é liberado para todos os colaboradores por padrão.
MNO_066	Norma de Utilização de Correio Eletrônico	10.0	15/08/14	• A análise deste documento foi realizada por conta da necessidade de abertura de chamado para liberação de acesso remoto ao e-mail corporativo (*webmail*). Convém que estas regras sejam

ID	Nome do Documento	Versão	Última Atualização	Análise do Documento
				sempre reforçadas aos usuários do BV e suas empresas.
MNO_067	Norma de Acesso Remoto aos Computadores Corporativos	12.0	26/06/15	• A análise deste documento foi realizada por conta da necessidade de abertura de chamado para liberação de acesso remoto aos computadores corporativos. Convém que estas regras sejam sempre reforçadas aos usuários do BV e suas empresas.
MNO_401	Norma de Utilização da Rede Corporativa Wireless	7.0	01/07/15	• A análise deste documento foi realizada por conta da necessidade de abertura de chamado para liberação de acesso as redes wireless (Corporativa, *BYOD* e Visitantes). Convém que estas regras sejam sempre reforçadas aos usuários do BV e suas empresas.
MNO_671	Norma de Segregação de Funções de Segurança da Informação	4.0	25/11/14	• A análise deste documento foi realizada por conta da importância da existência de documentação dos perfis de acesso aos sistemas desenvolvidos ou adquiridos pelo **Banco Votorantim**. • A cláusula 1.1.3 versa sobre responsabilidade do proprietário da informação (negócio) referente às definições dos perfis de acesso aos sistemas, com suporte das equipes de Desenvolvimento de Sistemas e Segurança da Informação. Esta responsabilidade deve ser reforçada pelos interlocutores de Segurança da Informação sempre que a organização estiver trabalhando o desenvolvimento ou a implantação de um novo sistema, visando estabelecer os controles adequados de Segregação de Funções. • As cláusulas 1.1.4 e 1.1.5 versam sobre a responsabilidade das áreas de Sistemas sobre a documentação efetiva dos perfis de acesso contendo sua finalidade, as funcionalidades e alçadas associadas ao perfil e incluindo as adequadas regras de Segregação de Funções, o que atualmente não é uma realidade, segundo informações prestadas pelas lideranças das áreas de Gestão de Acessos e Operações de SI (esta última que representa SI nas demandas junto ao time de Tecnologia).
MNO_675	Norma de Segurança no Desenvolvimento, Aquisição e Manutenção de Sistemas	8.0	16/06/15	• A análise desde documento foi realizada por conta da importância do desenvolvimento, aquisição ou manutenção de sistemas de forma segura, conforme estabelecido em linhas gerais pela cláusula 1.1.1 que versa sobre os aspectos de segurança da informação ser contemplados durante o Ciclo de Desenvolvimento de Sistemas. • A principal observação que nos cabe sobre este documento é que o mesmo contemple, além dos requisitos de segurança da informação, os requisitos de Gestão de Acessos, tais como estabelecidos na norma MNO_671 sobre a obrigatoriedade de elaboração de perfis de acesso aos sistemas com base em regras de segregação de funções e principalmente sobre sua documentação para fins de suporte posterior

ID	Nome do Documento	Versão	Última Atualização	Análise do Documento
				pela equipe de Gestão de Acessos Lógicos quando o sistema já estiver em produção.
MNO_677	Norma de Gestão da Segurança da Informação	4.0	23/01/14	• A análise deste documento foi realizada para melhor entendimento sobre a estrutura da área de Segurança da Informação do **Banco Votorantim**, seus Papéis e Responsabilidades e também para análise das responsabilidades associadas à área de Gestão de Acessos e seu processo correlato, conforme descrito nas cláusulas 1.4.1.d e 2.1.3. • Convém promover revisão da norma antes de janeiro de 2016 quando completará dois anos de vigência.
MNO_717	Norma de Desenvolvimento e Manutenção de Sistemas	5.0	20/03/15	• O documento em questão não faz referência em nenhum momento à MNO_675, Norma de Segurança no Desenvolvimento, Aquisição e Manutenção de Sistemas. Convém solicitar que esta norma seja apontada no item "Referências".
MNO_732	Norma de Classificação da Informação	5.0	13/03/14	• A análise deste documento foi realizada para melhor entendimento sobre os critérios atualmente estabelecidos sobre a classificação das informações pelo **Banco Votorantim**. • Convém promover revisão da norma antes de março de 2016 quando completará dois anos de vigência.
MNO_834	Norma de Concessão de Acesso aos Sistemas de Crédito	4.0	27/11/14	• Documento importante relacionado à concessão de acessos aos Sistemas de Crédito Web (PTA) e BI de Crédito. • Correção: na cláusula 2.1.1 alterar o nome da ferramenta de chamados "*ASK*" (descontinuada) para "CA *Service Desk*" (atual). • Avaliar a adição de cláusulas referentes a criação, alteração e revisão anual dos perfis por função (*RBAC*) em equivalência às cláusulas 4.1.1 e 5.1.1 já existentes no documento. • Convém promover revisão da norma para atualização das informações erradas e adição do escopo *RBAC*.
MNO_1088	Norma de Gestão de Níveis de Serviço de TI	5.0	11/06/15	• Documento analisado para validar se a cláusula 3.2.1, referente a solicitações de uso aos sistemas aplicativos, encontrava-se em conformidade com as outras Normas de Gestão de Acessos. • Convém, a tempo hábil, que a área de Segurança da Informação elabore um documento resumido, mas com o mesmo contexto, com a finalidade de informar seus *SLAs* e respectivos prazos de resolução de chamados a toda organização.
MNO_1156	Norma de Comissão de Segurança da Informação – Estrutura e Funcionamento	2.0	17/04/15	• A análise deste documento foi realizada para melhor entendimento sobre a estrutura da Comissão de Segurança da Informação, tendo em vista que um dos temas abordados em suas reuniões é Gestão de Acessos, conforme cláusula 2.1 (Atribuições e Temas Tratados).

ID	Nome do Documento	Versão	Última Atualização	Análise do Documento
MNO_1164	Norma de Acesso a Informações por Terceiros Contratados	1.0	21/02/14	• A análise deste documento foi realizada para melhor entendimento sobre o Acesso às Informações por Terceiros Contratados, conforme cláusula 1.3 (Controle). • Convém revisitar a necessidade de sua continuidade visto que o tema também é abordado em outras Normas, tais como MNO_315 e MNO_253.
MNO_1175	Norma de Operacionalização de Acessos de Sistemas para Cadastro de Propostas	1.0	28/04/14	• A análise deste documento foi realizada para melhor entendimento sobre a concessão, manutenção, transferência, e revogação de acessos aos sistemas de cadastramento de propostas. • As atividades descritas nesta norma eram endereçadas diretamente por e-mail ao analista Klélder (Operações de SI), sem o registro de chamados na ferramenta CA *Service Desk*. Tal fato se comprova ao percebermos que nenhuma cláusula da norma cita a necessidade de abertura de chamados (o que de fato ainda não ocorre atualmente). • Os usuários-chave das áreas correlatas ao tema já foram informados sobre a necessidade de cadastramento das respectivas categorias de chamados no CA *Service Desk* e posterior necessidade de abertura de chamados. Assim que isto for concluído, será necessário revisar o conteúdo desta norma de forma a contemplar o novo formato de solicitação. Além disso, cabe ressaltar que a última atualização da mesma já completou mais de um ano e que as atividades realizadas pelo analista Klélder já foram repassadas ao analista Nicolas da equipe N2 da Gestão de Acessos, portanto, já há uma defasagem entre o que a norma orienta (cita a área de Operações de SI como interlocutora) e o que está sendo praticado atualmente.
MNO_1207	Norma de Avaliação de Sistemas Pacote	2.0	11/05/15	• A análise deste documento foi realizada para avaliar se os requerimentos de Segurança da Informação e Gestão de Acessos estavam contemplados em suas cláusulas. • A cláusula 1.3.5 versa sobre a capacidade do Sistema "Pacote" relacionada à proteção de informações e dados, prevenindo acessos não autorizados, porém não cita a capacidade do referido sistema em permitir a elaboração e perfis de acesso baseados em regras de segregação de funções conforme a norma MNO_671 determina. • No item "Aprovadores" da norma não há menção à Segurança da Informação, porém, dada a relevância do tema, a área de SI deveria ser uma das aprovadoras antes de sua publicação oficial. • No item "Referências", as Normas MNO_671 (Norma de Segregação de Funções de Segurança da Informação) e MNO_675 (Norma de Segurança no Desenvolvimento, Aquisição e Manutenção de Sistemas) deveriam ter sido mencionadas.

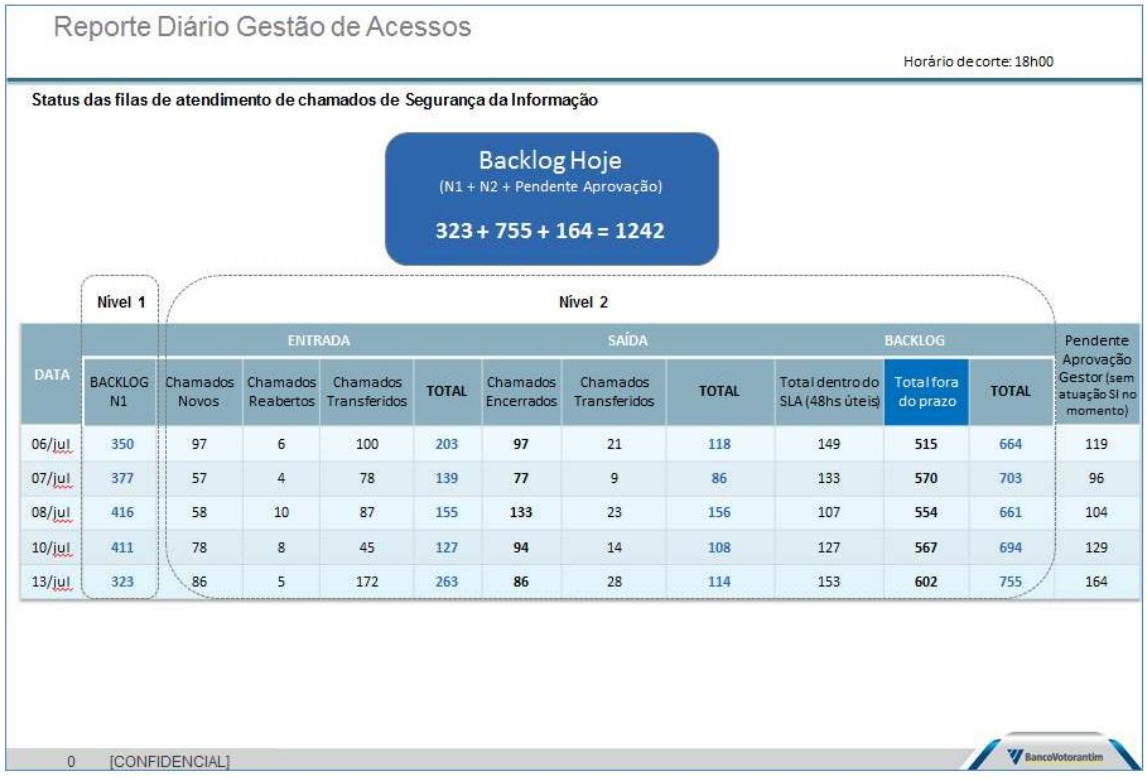
ID	Nome do Documento	Versão	Última Atualização	Análise do Documento
MNO_1212	Norma de Governar e Gerenciar os Processos e Serviços de Tecnologia	1.0	30/03/15	• Nenhuma informação relevante relacionada especificamente à Gestão de Acessos Lógicos. Análise do documento objetivou identificar algum relacionamento da Governança de Tecnologia com a Governança de Segurança da Informação / Gestão de Acessos.
MNO_1216	Norma de Operação do Serviço de Correio Eletrônico - E-mail	1.0	11/05/15	• Documento analisado para validar se a cláusula 2.2, referente ao controle e concessão de acesso às caixas de correio encontrava-se em conformidade com as outras normas de Gestão de Acessos correlatas ao assunto. • No item "Referências", as normas MNO_315 (Norma de Criação e Desativação de *Login* de Rede, Contas e Grupos de E-mail) e MNO_066 (Norma de Utilização de Correio Eletrônico) deveriam ter sido mencionadas.
MPC_005	Política Corporativa de Segurança da Informação	5.0	20/03/14	• A Política Corporativa de Segurança da Informação foi analisada com a finalidade de verificar a existência de cláusulas relacionadas à Gestão de Acessos Lógicos, fato positivo mediante a cláusula 4.3 (Gestão de Acessos) do referido documento.
MPC_030	Política Corporativa de Tecnologia da Informação	3.0	05/12/13	• A Política Corporativa de Tecnologia da Informação foi analisada com a finalidade de verificar a existência de cláusulas relacionadas à Segurança da Informação e Gestão de Acessos Lógicos no contexto da área de Tecnologia, fato positivo mediante a cláusula 1.5 do referido documento que indica a existência de um conjunto de Políticas e Normas sobre o tema. • Convém avaliar a necessidade de atualização deste documento, visto que completará dois anos de vigência em dezembro de 2015.
MPR_1341	Procedimento de Revisão de Acesso a Sistemas e Bancos de Dados	1.0	11/04/14	• Refere-se a um dos procedimentos e fluxos principais do processo da área: Revisão de Acessos a Sistemas e Bancos de Dados. • Convém promover uma revisão deste procedimento para validar o fluxo atualmente praticado e atualizar informações (partes do documento ainda citam a ferramenta de registro de chamados *ASK*, já substituída pelo CA *Service Desk*). • Convém promover um workshop ou treinamento após a revisão deste material para todos os analistas que atuam em Gestão de Acessos para reciclagem de conhecimentos.

3.2.2 Indicadores

Durante as análises, questionamos a existência de indicadores oficiais (*KPIs*) de Gestão de Acessos, elaborados em frequência pré-determinada e formalmente apresentados à gerência e alta direção da área de Segurança da Informação.

Juliano Panciera, Coordenador da Gestão de Acessos, nos apresentou o "*Reporte Diário da Gestão de Acessos*", sendo este o único indicador oficial da área e enviado diariamente por e-mail aos responsáveis pela Segurança da Informação, incluindo o Diretor Wagner Pugliese.

Demonstramos abaixo um exemplo deste reporte, datado de 13 de julho de 2015.



Reporte Diário Gestão de Acessos

Horário de corte: 18h00

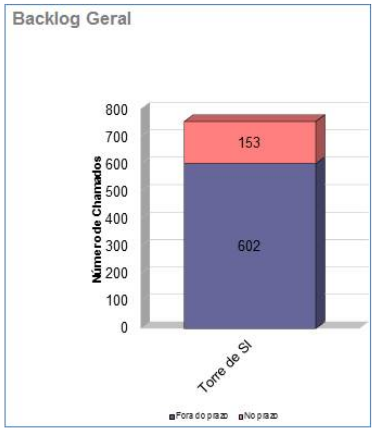
Status das filas de atendimento de chamados de Segurança da Informação

Backlog Hoje
(N1 + N2 + Pendente Aprovação)
323 + 755 + 164 = 1242

	Nível 1	Nível 2										
		ENTRADA				SAÍDA			BACKLOG			
DATA	BACKLOG N1	Chamados Novos	Chamados Reabertos	Chamados Transferidos	TOTAL	Chamados Encerrados	Chamados Transferidos	TOTAL	Total dentro do SLA (48hs úteis)	Total fora do prazo	TOTAL	Pendente Aprovação Gestor (sem atuação SI no momento)
06/jul	350	97	6	100	203	97	21	118	149	515	664	119
07/jul	377	57	4	78	139	77	9	86	133	570	703	96
08/jul	416	58	10	87	155	133	23	156	107	554	661	104
10/jul	411	78	8	45	127	94	14	108	127	567	694	129
13/jul	323	86	5	172	263	86	28	114	153	602	755	164

0 [CONFIDENCIAL]

Aging Nível 2:



Idade da Violação	Volume de chamados em atraso
Até 01 Dia	1
Entre 10 à 30 dias	348
Entre 2 à 5 dias	55
Entre 6 à 10 dias	110
Superior à 30 dias	88

O reporte elaborado representava uma "fotografia" obtida no horário de corte estipulado (18h00) e demonstrava como *Backlog*, a quantidade total de chamados que ainda estavam aguardando resolução, incluindo um breve histórico comparativo dos cinco últimos dias e também a "idade" ou *aging* de todos os chamados pendentes em N2 (somando os chamados dentro e fora do prazo de atendimento, padronizado em 48h úteis nesta visão).

Esta visão de chamados considerava como N2, a consolidação de todos os chamados em tratamento pelas células de atendimento N2 (Sonda IT) e "Especialistas N3 e Operações de SI" (**Banco Votorantim**).

Cabe ressaltar que, o objetivo principal deste *report* era acompanhar a evolução (aumento ou redução) do *Backlog*, não apresentando nenhuma informação percentual ou até mesmo meta a ser perseguida.

Neste contexto, visando aprimorar a compreensão dos volumes de chamados por grupo solucionador, propusemos e implementamos em tempo de projeto, o painel abaixo:

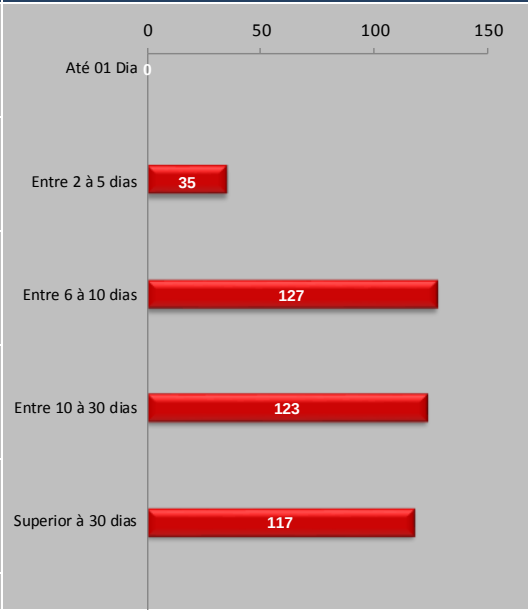
Report Diário de Chamados de SI

26/08/2015

BancoVotorantim

Chamados de SI - "Em Atendimento" (Aberto, Em atendimento, Reaberto)						Chamados de SI - Outros Status			Chamados SI
Área	Qtd. dentro do Prazo	%	Qtd. fora do Prazo (BACKLOG)	%	TOTAL Em atendimento	Em Aprovação	Pendente Cliente	Aguardando Fornecedor	Todos os STATUS
SI N1 (Sonda)	46	73%	17	27%	63	2	48	0	113
SI N2 (Sonda)	88	39%	135	61%	223	156	32	5	416
SI Especialistas (N3)	37	18%	167	82%	204	0	3	10	217
SI Operação	10	11%	83	89%	93	8	0	0	101
Volume Total	**181**	**31%**	**402**	**69%**	**583**	**166**	**83**	**15**	**847**

Idade do Backlog					
Idade da Violação	Área Ofensora	Volumes		%	Gráfico Backlog
Até 01 Dia	SI N1 (Sonda)	0	**0**	**0%**	
	SI N2 (Sonda)	0			
	SI Especialistas (N3)	0			
	SI Operação	0			
Entre 2 à 5 dias	SI N1 (Sonda)	4	**35**	**9%**	
	SI N2 (Sonda)	21			
	SI Especialistas (N3)	6			
	SI Operação	4			
Entre 6 à 10 dias	SI N1 (Sonda)	4	**127**	**32%**	
	SI N2 (Sonda)	56			
	SI Especialistas (N3)	32			
	SI Operação	35			
Entre 10 à 30 dias	SI N1 (Sonda)	9	**123**	**31%**	
	SI N2 (Sonda)	44			
	SI Especialistas (N3)	51			
	SI Operação	19			
Superior à 30 dias	SI N1 (Sonda)	0	**117**	**29%**	
	SI N2 (Sonda)	14			
	SI Especialistas (N3)	78			
	SI Operação	25			
			402	**100%**	



3.2.3 *SLAs*

Durante a fase de análises sobre o processo de Gestão de Acessos Lógicos do **Banco Votorantim** questionamos a existência de prazos de resolução de chamados de acesso (*SLAs*), formalmente acordados entre a área de Segurança da Informação e as áreas de negócios.

Fomos informados sobre a **existência de um *SLA* "padrão" de 48h úteis não formalizado junto às áreas de negócios**, o qual desconsidera o período em que os chamados permanecem em aprovação. A etapa de aprovações possui um prazo máximo de 5 (cinco) dias úteis, reconhecido pelos aprovadores através de escalada automática através da ferramenta CA *Service Desk*, sendo que, em caso de não aprovação após o término deste período, o chamado é encerrado automaticamente com status "encerrado por falta de aprovação".

Apesar de existir este *SLA* "padrão", o qual é apresentado no único indicador oficial da área, já **ocorreram diversos acordos pontuais entre a Gestão de Acessos e algumas áreas de negócios**, onde determinadas categorias de chamados foram parametrizadas na ferramenta CA *Service Desk* com prazos de resolução combinados, tais como, 8 horas úteis, 16 horas úteis, 32 horas úteis, entre outros.

A maior dificuldade relacionada a este assunto encontra-se exatamente na efetiva gestão desses níveis de serviço (*SLAs*), os quais foram **acordados ao longo do tempo, muitas vezes sem a adequada formalização, mas principalmente sem a existência de um processo de controle e revisão periódica**, como preconizam as práticas de mercado.

Além disso, alguns analistas mais novos acabam desconhecendo o fato de existirem "*SLAs* distintos" para determinados sistemas ou categorias de chamados, dificultando ainda mais o entendimento sobre o que é realmente prioritário (os analistas mais antigos optam por resolverem prioritariamente os chamados com *SLAs* mais agressivos, com base em sua experiência e entendimento sobre as urgências das áreas de negócios solicitantes, mas não pelo fato dos tempos de resolução combinados ser menores do que o "padrão").

3.2.4 LPG – Lista de Proprietários e Gestores dos Sistemas

Tendo em vista sua importância como um dos principais artefatos (documento de apoio) utilizado para operacionalização do processo de Gestão de Acessos Lógicos do **Banco Votorantim**, destacamos um tópico exclusivo para a análise da "LPG", sigla para Lista de Proprietários e Gestores dos Sistemas.

Existe um documento normativo MNO_025 (Norma de Proprietários e Gestores dos Sistemas de Informação) que estabelece as regras para caracterizar as responsabilidades dos gestores em relação aos sistemas, incluindo a manutenção/atualização da LPG. A análise desta norma já foi apresentada no tópico 3.2.1 deste documento.

A LPG é uma listagem mantida pela área de Segurança da Informação que contém todos os Sistemas de Informação utilizados pelo **Banco Votorantim** e suas empresas, apresentando informações como:

- Nome do Sistema;
- Sigla do Sistema;
- Sigla da MDS (sigla utilizada pela área de TI-Sistemas em sua Metodologia de Desenvolvimento de Sistemas);
- Perfis associados ao Sistema;
- Nome do Proprietário do Sistema;
- Nome do(s) Gestor(es) de Acesso ao Sistema – para aprovações de solicitações de acesso;
- Nome do(s) Gestor(es) de Mudanças – para aprovações de alterações no sistema;
- Informação se o sistema pertence ao escopo *RBAC*,
- Entre outras informações.

As informações dos Proprietários e Gestores de Acesso aos Sistemas são amplamente utilizadas pela equipe de atendimento N1, pois os aprovadores responsáveis por cada sistema são atribuídos manualmente nos fluxos de aprovação de todos os chamados de acesso.

Apesar da existência e da importância da LPG, cabe ressaltar que **não foi identificada nenhuma documentação que contivesse uma descrição completa de todos os sistemas e seus respectivos perfis de acesso adequadamente descritos** (incluindo a finalidade de cada perfil e suas funcionalidades, permissões e alçadas associadas).

Outro item importante que nos foi informado é a **existência de uma segunda lista de sistemas, mantida pela área de Tecnologia da Informação** e utilizada no Ciclo / Metodologia de Desenvolvimento de Sistemas. Por conta disso, a LPG apresenta uma coluna que menciona a "sigla do sistema na MDS".

A existência de duas listas "oficiais" de sistemas prejudica muito o controle, visto ambas não serem totalmente equivalentes, mediante a divergência de conceitos sobre a diferenciação entre sistemas e módulos de sistemas – o que impacta a quantidade de itens apresentada em cada lista (cada uma possui uma quantidade diferente de sistemas). Foi relatado que já existe um Risco mapeado que endereça essa questão, mas dada a relevância do tema, consideramos imprescindível que o mesmo fosse apontado neste documento.

3.3 Ferramentas

Durante as análises, identificamos as principais ferramentas que suportam a operacionalização do processo de Gestão de Acessos Lógicos do **Banco Votorantim**, tais como ***AD* e VF ACESSO** (que contém as bases de usuários e perfis associados aos mesmos), **IDM** (ferramenta de gestão de identidades da Novell) e **CA *Service Desk*** (ferramenta de registro e controle de chamados de acesso, também utilizada e mantida pela área de Tecnologia).

3.3.1 AD, VF ACESSO e IDM

Fomos informados que aproximadamente 70% dos sistemas de informação utilizados pelo **Banco Votorantim**, possuem suas bases de usuários integradas com *AD* e VF ACESSO, o que garante a concessão e revogação de acessos interligada aos *Logins* de rede (principal identificador único de cada colaborador). Na eventual necessidade de promover revogação imediata dos acessos de um colaborador, por exemplo, em caso de demissão, os acessos aos sistemas integrados são revogados automaticamente assim que seu *Login* de rede for inativado. Exemplos de sistemas integrados: Sistemas "PTA" e Sistema PGFO.

Em relação ao restante dos sistemas que não possuem integração com *AD* e VF ACESSO (aproximadamente 30%), a administração dos usuários, perfis e senhas ocorre de maneira totalmente independente, sendo que, para alguns sistemas, a identificação do usuário no (*Login* de acesso) é completamente diferente do *Login* de rede, o que dificulta ainda mais sua administração. Na eventual necessidade de promover a revogação imediata dos acessos de um colaborador, por exemplo, em caso de demissão, os acessos a estes sistemas são revogados um a um, de forma manual. Exemplos de sistemas nesta situação: CETIP, SISBACEN, TOTALBANCO.

Sobre o IDM (sistema de gestão de identidades da Novell), citamos como fato relevante a iniciativa de automatização da solicitação de perfis de acesso através de *workflow*, diretamente por esta ferramenta. Nesta situação, as aprovações ocorrem da própria ferramenta e o principal benefício é a concessão automática e imediata dos acessos após o término do fluxo de aprovações.

3.3.2 CA *Service Desk*

Em relação à ferramenta CA *Service Desk*, principal meio de controle das solicitações de acesso, identificamos dificuldades em uma parcela significativa dos envolvidos na abertura e acompanhamento dos chamados. Isto nos foi relatado pelos usuários-chave entrevistados, por alguns analistas de atendimento e experimentado pelo consultor Jorge Maluf, durante uma simulação para abertura de um chamado de acesso.

A lista de categorias de chamados (Catálogo) que existe atualmente na ferramenta CA *Service Desk* teve origem na ferramenta ASK, utilizada anteriormente pelo **Banco Votorantim**. Sua estrutura é extremamente extensa, o que resulta em grande confusão a qualquer usuário que pretenda registrar seu chamado de solicitação de acesso diretamente pela interface de abertura, sem a necessidade de realizar uma chamada para o *Service Desk* ou enviar um e-mail.

O ponto de partida na árvore de categorização apresenta um nível de informação pouco amigável ao usuário comum, tal como "*Software*", "Sistemas", "*Hardware*", e logo no nível seguinte mais uma enorme lista de opções. Fomos informados sobre um atalho para filtro e busca de categorias (utilização do caractere '%') que não é amplamente conhecido, segundo pudemos constatar.

Ainda que o usuário encontre a categoria correta para abertura de seu chamado de solicitação de acesso, a ferramenta indica apenas o preenchimento de um campo texto onde deve ser descrita a necessidade. Não é solicitado o preenchimento de nenhum campo específico adicional, que obrigue o usuário a informar dados necessários para melhor compreensão da solicitação e pronto-atendimento pelos analistas de acesso.
Neste contexto pouco familiar ao seu dia-a-dia, o usuário acaba sentindo-se mais confortável efetuando sua solicitação de acesso por e-mail (nem sempre informando todos os dados necessários para compreensão e pronto-atendimento à sua solicitação).

Além disso, alguns usuários-chave que atuam como pontos-focais, informaram as dificuldades que enfrentam para consultar e cobrar *status* dos chamados de acesso de todos os colaboradores de suas respectivas áreas de negócios. Como o acesso à consulta de chamados abertos por outros usuários é restrito, esta atividade se torna árdua e despende muito tempo destes profissionais.

Isto se evidencia pelo fato da categoria de chamados "NÃO TECNICA.NIVEL 1.CONSULTA DE CHAMADO_SI" ser a segunda maior ofensora para a Gestão de Acessos. A implantação da consulta de chamados via URA, possibilitou uma melhora considerável em relação a este cenário, mas não atende por completo as necessidades dos pontos focais que precisam de mais informações além daquelas informadas automaticamente pela URA (ex.: nome do aprovador que ainda falta aprovar o chamado).

3.4 Visão dos Negócios

Neste tópico, apresentamos os principais relatos obtidos durante as entrevistas com os clientes internos e usuários de negócios, demonstrando sua percepção e experiência com a prestação de serviços da Gestão de Acessos Lógicos para suas áreas, enfatizando os impactos decorrentes no caso do atendimento tardio de suas solicitações.

Todas as reuniões junto a este público foram acompanhadas pelo coordenador da área, Juliano Panciera, e trouxeram à tona percepções sobre as reais dificuldades enfrentadas com o processo de Gestão de Acessos Lógicos do **Banco Votorantim**.

Cada usuário-chave, à sua maneira, comentou alguma frase emblemática, as quais consolidamos e apresentamos abaixo, de forma contextual e não literal conforme expressado:

> *"O chamado acaba sendo atendido somente quando eu aciono o Juliano (eu e ele acabamos parando nosso trabalho para dar foco no chamado). Aí resolve!"*

> *"Se o acesso demora muito para ser liberado, estamos perdendo dinheiro com o analista parado... e depois meu chefe pergunta: quem paga essa conta?"*

> *"Vou fingir que nem comentei isso, pois vocês são de SI, mas apesar de sempre reforçar com o pessoal do meu time para que isso não aconteça, quando o acesso demora, as pessoas 'emprestam' senha..."*

> *"O N1 (7800) é muito cordial e atencioso. Realmente quer ajudar, mas muitas vezes não entende o que eu estou falando ou pedindo..."*

> *"Na minha área, criei uma posição administrativa para dar conta de acompanhar e cobrar os chamados, caso contrário não anda..."*

> *"As pessoas possuem dificuldade para utilizar o CA para abertura de chamados. Como Ponto Focal eu já me acostumei, mas no começo foi difícil."*

> *"Eu acabo 'ensinando' como fazer a liberação do Portal Jurídico, pois fui atrás de entender o procedimento de tantos problemas que já tive..."*

> *"... o RBAC parece bem interessante, mas preciso entender."*

> *"O tempo de atendimento é sofrível, muitas vezes o chamado fica 10, 15 ou até 30 dias pendente... e acabo abrindo outro."*

> *"Se vocês analisarem os chamados antigos, já deve ter muita 'coisa' que foi reaberta e solucionada porque não saía do lugar..."*

Durante estas reuniões, Juliano apresentou o objetivo do projeto de *Gap Analysis* e informou aos usuários-chave, com muita transparência, a situação e os volumes do *Backlog* e também todo o planejamento e esforços que SI, Gestão de Acessos e Sonda IT vem trabalhando para melhorar efetivamente a prestação de serviços aos mesmos. A receptividade dos usuários foi muito positiva e é notório que todos ficaram muito satisfeitos por terem sido consultados e poderem expor de forma clara e objetiva seus pontos de preocupação e necessidades.

Uma das percepções mais positivas informadas pelos usuários foi a atuação sempre colaborativa do Juliano em entender as urgências e demandar aos analistas de acesso as priorizações solicitadas, relatando que o mesmo age de forma muito parceira com suas áreas.

Também questionamos, a título de mapeamento de expectativas, quais seriam os prazos aceitáveis que os usuários-chave entendiam como adequados para resolução dos chamados de acesso. As respostas foram as mais diversas possíveis, mas já representam um bom insumo para que, futuramente, os *SLAs* sejam acordados e formalizados entre SI e as respectivas áreas. Informamos abaixo o resumo das respostas:

- **SAC** – até 2 (dois) dias após as aprovações, enquanto o atendente do SAC não estiver em operação. Caso já esteja em operação e precise adicionar ou alterar um acesso, deve ser imediato após as aprovações, pois podemos ficar com os *SLAs* do SAC comprometidos se não for dessa forma.
- **Cobrança** – até 1 (um) dia após as aprovações. 3 (três) dias considerando o ciclo completo, desde o pedido até a efetiva concessão do acesso – consideram 5 (cinco) dias úteis muito tempo para o ciclo de aprovações.

- **Jurídico** – já estão contratando advogados terceiros e assessorias jurídicas com até 10 (dez) dias de antecedência somente para evitar que os mesmos fiquem sem produzir, aguardando as liberações de acessos. Sobre os prazos, entendem que o Jurídico poderá se adaptar a qualquer prazo que Gestão de Acessos entenda como o mínimo necessário para a prestação de um serviço de qualidade, desde que seja efetivamente cumprido.
- **Cadastro, Desaverbação, Recebimentos e Inadimplência** – atualmente são atendidos sem o registro de chamados, o que flexibiliza e agiliza os tempos de atendimento. Informam que há situações onde a liberação de um acesso precisa ser praticamente imediata mediante prioridades extremas do negócio, tal como a liberação de margem ou acesso a determinados sites públicos de prefeituras ou governos. Entendem que prazos podem ser acordados junto à Gestão de Acessos, desde que haja a possibilidade de atendimento "imediato" dependendo do caso, evitando penalizações, notificações do BACEN, etc.
- **Suporte Comercial do Varejo** – já possui um prazo de atendimento combinado com Gestão de Acessos de 8h úteis, o qual foi relatado que não está sendo cumprido à risca como acontecia no passado. A área possui permissão para visualizar todos os chamados de seus colaboradores e acaba desperdiçando muito tempo em cobranças pelo andamento dos mesmos – buscando ser atendida dentro deste prazo.

3.5 Top 10 Ofensores

Neste tópico, apresentamos a análise e/ou tratativa realizada sobre as *Top* 10 Categorias Ofensoras, que juntas apresentaram as maiores quantidades de chamados de janeiro/15 a agosto/15 (parcial) e somadas, representavam mais de 40% do volume total.

#	Categoria de Chamado	Qtd. Chamados	% sobre Total	% Acum.	Avaliação/Tratativa
1	INFRAESTRUTURA.*ACTIVE DIRECTORY*.USUARIO.DESBLOQUEAR	2.908	8,85%	8,85%	• Atividade de desbloqueio de usuário de rede foi automatizada via URA e já se encontra em produção desde o final de julho de 2015.
2	NAO TECNICA.NIVEL 1.CONSULTA DE CHAMADO_SI	2.885	8,78%	17,63%	• Após a eliminação do *Backlog*, consideramos que haverá redução de chamados nesta categoria. Além disso, também foi implementada a consulta de chamados pela URA, sendo liberada a consulta de chamados pelos pontos focais das áreas de negócios.
3	INFRAESTRUTURA.*ACTIVE DIRECTORY*.DIRETORIO DE REDE.LIBERAR ACESSO	2.432	7,40%	25,03%	• Esta categoria de chamados representa grande desafio aos analistas de acesso, mediante ao grande volume de diretórios existentes, dificuldade de localizar o responsável correto (não há formalização da alteração de responsáveis). Também há casos de diretórios que não possuem responsáveis identificados. A área de Governança de SI já está buscando endereçar uma revisão completa de todos os responsáveis pelos diretórios.
4	INFRAESTRUTURA.*ACTIVE DIRECTORY*.USUARIO.RESET DE SENHA	1.673	5,09%	30,12%	• Atividade de *reset* de senha de rede foi automatizada via URA e retirada de produção por solicitação de Auditoria. Entretanto, já foi elaborada uma defesa, a qual promove o retorno desta funcionalidade para produção, tendo em vista seu benefício operacional aliado às medidas de mitigação existentes.
5	SEGURANCA DA INFORMACAO.SI GERAL.GRUPO DE SEGURANCA.INCLUIR USUARIO	1.104	3,36%	33,48%	• Esta categoria pode ser atribuída à diversas solicitações de acessos pela inclusão de um usuário a um grupo de segurança, como por exemplo: rede wireless, grupos de e-mail, administração de servidores, acesso a determinado diretório de rede, entre outros. Cabe avaliar oportunamente a elaboração de categorias de

#	Categoria de Chamado	Qtd. Chamados	% sobre Total	% Acum.	Avaliação/Tratativa
					chamados específicas, com a finalidade de distinguir os diversos tipos de solicitação pela inclusão de usuários em grupos de segurança.
6	SISTEMAS.*ERP*M - *ERP* - MICROSIGA.LIBERAR ACESSO	588	1,79%	35,27%	• Atividade de liberação de acessos ao *ERP* estava centralizada no analista de N2 Isaías. Contudo, já foi realizada a transmissão do conhecimento para o analista de N2 Bem-Hur que já se encontra realizando esta atividade, o que dinamizou ainda mais o atendimento aos usuários solicitantes. • Também foi verificado que alguns chamados foram atribuídos equivocadamente a esta categoria, quando na verdade deveriam ter sido categorizados como "manutenções de alçadas" no *ERP*.
7	NAO TECNICA.NIVEL 1.DUVIDA.ORIENTACAO EM LINHA	502	1,53%	36,79%	• Após a eliminação do *Backlog*, consideramos que haverá redução de chamados nesta categoria, tendo em vista que a maioria dos chamados de dúvidas eram relacionados realmente a consultas sobre chamados em andamento.
8	HARDWARE.TOKEN.SOLICITAR.DESBLOQUEIO	444	1,35%	38,14%	• Atividade de substituição do *token* físico pelo *token* fixo promoveu esta categoria como ofensora. Chamados nesta categoria devem ser acompanhados a partir de setembro/2015 pois estará em execução a substituição do *token* fixo pelo *token* por aplicativo, instalado nos *smatphones* dos colaboradores do BV.
9	SISTEMAS.CRED.URAS - URA DE CREDITO.RESET DE SENHA	419	1,27%	39,42%	• Está em andamento um estudo sobre automatização do *reset* de senha do Código URA, sendo conduzido pelo Juliano Panciera com apoio do analista de N2 Isaías.
10	SISTEMAS.SNGO - SNG ONLINE - MEGADATA ONLINE.RESET DE SENHA	385	1,17%	40,59%	• Atividade foi transferida de N3 para N2 recentemente. Atualmente é realizada pela analista Dilma e será feito o compartilhamento de conhecimento para que outros analistas de N2 também possam atender a estes chamados. Além disso, houve alinhamento com a usuária-chave do SAC (Lucimara Maçorano) esclarecendo questões técnicas que levavam ao bloqueio dos usuários (inatividade após 90 dias). A área foi orientada a solicitar que os atendentes efetuassem *Login* no sistema ao menos uma vez

#	Categoria de Chamado	Qtd. Chamados	% sobre Total	% Acum.	Avaliação/Tratativa
					por semana para evitar o bloqueio, o que já diminuiu a quantidade de chamados relacionados à esta categoria.
1539	DEMAIS CATEGORIAS	19.525	59,41%	-	-
1549	**TOTAL GERAL**	**32.865**	**100,0%**	-	-

4 RECOMENDAÇÕES DE MELHORIAS

Tomando como base as análises demonstradas nas seções anteriores deste relatório, apresentamos a seguir as recomendações de ações para melhorar o desempenho e a imagem do processo de Gestão de Acessos Lógicos do **Banco Votorantim** perante seus clientes internos e usuários.

Em 28 de agosto de 2015, ocorreu a última reunião executiva no **Banco Votorantim**, antes da entrega final deste documento, referente aos serviços prestados pela Sonda IT à área de Segurança da Informação, na qual apresentamos um pacote inicial de recomendações de melhorias, conforme solicitado dias antes pelo recém-contratado *Information Security Officer* – Leonardo Carmona. Carmona havia nos solicitados auxílio imediato que permitisse a eliminação do *Backlog* de chamados da forma mais urgente e eficiente possível, através de ações rápidas e objetivas.

Diante desta solicitação e, munidos dos argumentos e relatos dos usuários-chave de negócio apresentados no tópico 3.4, propusemos inicialmente **a revisão dos papéis e responsabilidades para todas as funções relativas à Gestão de Acessos**, de forma a possibilitar que cada envolvido pudesse compreender e desempenhar seu papel de maneira mais adequada, com a finalidade de corrigir desvios ocasionados pelo tumultuado cenário operacional instaurado (grande *Backlog*).

Nossa recomendação de Papéis e Responsabilidades:

Papel	Empresa	Responsabilidades
Coordenação de Gestão de Acessos	**Banco Votorantim**	• Ser o responsável por manter os Planos de Ação em dia e em execução. • Possuir conhecimentos sobre a estrutura do Banco, principais áreas clientes e suas necessidades / expectativas. • Realizar Prestação de Contas periódica sobre os chamados e *SLAs* para estas áreas clientes. • Promover o relacionamento com as áreas clientes evitando se envolver no operacional (apenas se as lideranças operacionais já tiverem sido escaladas). • Fomentar o PDCA dentro da Gestão de Acessos.
Especialistas de Gestão de Acessos	**Banco Votorantim**	• Ser o nível "tático" efetivo dentro da Gestão de Acessos Lógicos do BV, sem atender chamados. • Focar a implantação de novos projetos e tecnologias relacionadas a gestão de acessos (ex.: *RBAC*), buscando sempre o melhor nível de automatização possível. • Ser os representantes efetivos da Gestão de Acessos Lógicos do BV nos processos das outras áreas (Ex.: TI).

Papel	Empresa	Responsabilidades
Analistas de Nível 3 (N3)	**Banco Votorantim**	• Ser o nível "tático" dentro da Gestão de Acessos, mas também atender chamados. • Possuir conhecimentos sólidos sobre os sistemas do banco, sistemas de gestão de acessos e também sobre as áreas críticas do negócio que são sensíveis ao contexto de GA. • Investigar ou orquestrar a investigação (quando necessária a participação de TI) das causas de problemas técnicos relacionados a usuários, perfis, etc. • Possuir facilidade e didática para transmitir conhecimentos através de documentação e treinamentos ministrados periodicamente aos times de N2 e N1.
Analistas de Nível 2 (N2)	Sonda IT	• Ser o nível especializado na resolução de chamados (solucionadores). • Realizar atividades 100% focadas em atendimento de chamados. • Possuir conhecimentos técnicos avançados sobre os sistemas e seus respectivos módulos de gestão de acessos lógicos (principalmente quando a gestão de acessos é realizada manualmente). • Possuir conhecimentos baseados em instruções de trabalho, treinamentos efetivos e vivência prática (experiência).
Analistas de Nível 1 (N1)	Sonda IT	• Ser o nível mais operacional na Gestão de Acessos Lógicos do BV, com foco no atendimento telefônico, abertura e resolução de chamados menos complexos. • Possuir compreensão efetiva da solicitação do usuário é muito importante. • Reconhecer a "linguagem do Banco" e identificar os sistemas e áreas mais críticas. • Possuir conhecimentos baseados em instruções de trabalho, base de conhecimento e treinamentos efetivos.

De forma a proporcionar aos líderes da área de Gestão de Acessos um instrumento de gestão que suportasse as iniciativas de melhorias, desenvolvemos um *template* de Plano de Ação, para ser utilizado e mantido atualizado com o andamento e resultados obtidos. Como marco inicial, elaboramos dois planos que denominados "Planos de Ação Rápidos", que tinham por objetivo:

- Promover acompanhamento e finalização de iniciativas pendentes;
- Liberar FTE (*full-time equivalent*) de analistas possibilitando foco em *Backlog* de chamados (ex.: manutenção de alçadas no *ERP*);
- Redução de chamados pela transferência de atividades executadas por Gestão de Acessos para as áreas corretas (ex.: manutenção de alçadas no *ERP*);

- Redução de tempo de atendimento em atividades específicas (ex.: tombamento da gestão de acessos do *Payware* para o BV).

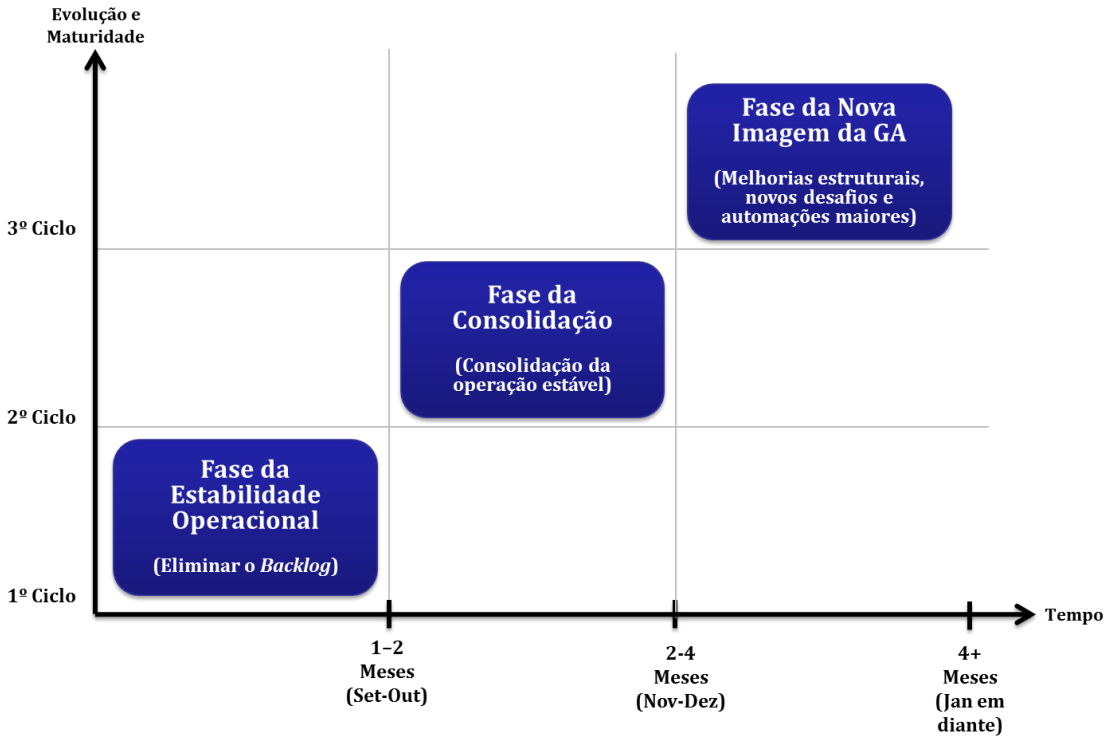
Plano de Ação para Tombamento da Gestão de Acessos do Payware da HP para o BV

Documento elaborado por Jorge Maluf, Mauricio Celentano e Hugo Barros em 21/08/15
Última atualização em 27/08/15

EXEMPLO

ID	Atividade	Responsável	Data	% Executado	Status ref. ao Prazo	Observações
1	Refazer o teste no Payware para validar se as permissões de criação de acessos e vinculação de perfis estão funcionando corretamente.	Danilo Caetano Hugo Barros	24/08/2015	100%	☺	-
2	Se não estiver resolvido, escalar Gerente de Contas da HP.	Juliano Panciera	24/08/2015	100%	☺	-
3	Se não estiver resolvido, escalar Rodrigo Rios (responsável da BV Financeira). Copiar Eduardo Guastella na cobrança.	Juliano Panciera	24/08/2015	100%	☺	-
4	Após 5 dias úteis, testar novamente.	Danilo Caetano Hugo Barros	31/08/2015			
5	Se não estiver resolvido, cobrar Rodrigo Rios (BV Financeira) e Richard (Gerente de Contas da HP. Copiar Leonardo Carmona na cobrança.	Juliano Panciera	31/08/2015			
6	Após 5 dias úteis, testar novamente.	Danilo Caetano Hugo Barros	08/09/2015			
7	Se não estiver resolvido, solicitar que a cobrança seja feita pelo Eduardo Guastella e/ou Leonardo Carmona.	Juliano Panciera	08/09/2015			
8	Escalar problema para nível hierárquico superior na HP (Diretoria).	Eduardo Guastella Leonardo Carmona	08/09/2015			

Uma vez proposta a revisão de papéis e responsabilidades, recomendamos a divisão das ações em três fases, sendo a primeira focada na **eliminação do *Backlog*** (Fase da Estabilidade Operacional), a segunda na **consolidação da operação estável sobre um *Backlog* controlado e reduzido a um nível aceitável** (Fase da Consolidação) e a terceira e última focada em **melhorias estruturais, automatizações de maior porte e aproximação com os clientes e usuários** (Fase da "Nova Imagem" da Gestão de Acessos). Este modelo foi proposto sobre uma vertente de aumento de maturidade ao longo do tempo, o qual demonstramos abaixo:



4.1 Fase da Estabilidade Operacional

A seguir, apresentamos as recomendações de ações de melhorias, encapsuladas na "Fase de Estabilidade Operacional" e que já foram apresentadas na reunião de 28 de agosto de 2015.

Em uma iniciativa conjunta da Sonda IT com os responsáveis pela área de Segurança da Informação, grande parte destas ações já se tornou parte integrante de um "**Plano de Ação para Estabilidade Operacional**". Com base nisto é possível afirmar que algumas ações já tenham sido efetivamente implantadas, mesmo que documentadas neste relatório.

Para cada recomendação, apresentaremos seu ID (identificador único que não está relacionado a prioridade de execução), o fato que originou a recomendação, o benefício esperado e uma visão macro das ações para sua implementação.

Nossas recomendações para esta fase são:

ID 01	SANEAR O *BACKLOG* DE CHAMADOS

- **Fato:** Durante as sessões de entrevistas, alguns usuários-chave nos informaram que os colaboradores de seus times realizavam a abertura de novos chamados, quando o atendimento ao primeiro chamado aberto era demasiadamente demorado (inclusive recomendaram que fizéssemos a análise da base de chamados, pois encontraríamos solicitações antigas que já haviam sido resolvidas).
- **Benefício:** Reduzir o universo de chamados a serem efetivamente tratados, eliminando registros redundantes ou que já se tornaram desnecessários devido ao tempo em que estão pendentes.
- **Ações:** Toda a base de chamados pendentes deve ser classificada por data (chamados mais antigos para os mais novos), analisada e separada por similaridade através da busca por palavras-chave ou categorias comuns. Após isso, deve ser realizado o fechamento massivo dos chamados, através de critérios estabelecidos pela liderança da área, tais como idade (*aging*), relevância atual e/ou até consulta aos solicitantes.

ID 02	IMPLANTAR GESTÃO À VISTA PARA O N2

- **Fato:** Baixa visibilidade dos analistas de acesso em N2 sobre os volumes de chamados e situação das filas de atendimento. Analistas de acesso em N2 devem atuar 100% de seu

tempo sobre as filas de atendimento de chamados e precisam reagir prontamente ao volume quando há situações de pico ou geração de *Backlog*

- **Benefício:** Sensibilizar os analistas apresentando os volumes de chamados e permitir que os mesmos possam visualizar as evoluções de seus esforços.
- **Ações:** Instalar uma televisão em local visível por todos os analistas de N2 e N3, apresentando um *dashboard* contendo a quantidade total de chamados em *Backlog* e em tratamento por fila de suporte. Avaliar oportunamente a exibição de um ranking de produtividade neste *dashboard*.

ID 03	INSTALAR DOIS MONITORES PARA TODOS OS ANALISTAS DE ACESSO (N2 e N3)

- **Fato:** Durante as observações, pudemos verificar que apenas alguns analistas de acesso (em N2 e N3) possuíam dois monitores para realização de suas atividades.
- **Benefício:** Esta é uma melhor prática amplamente utilizada por equipes de suporte, onde um monitor permanece com a ferramenta de chamados aberta o tempo todo e o outro é utilizado para abertura das consoles que o analista necessita para realizar os atendimentos dos chamados. Os ganhos de produtividade são bem significantes.
- **Ações:** Instalar o segundo monitor para todos os analistas que ainda não o possuam.

ID 04	MOBILIZAR EQUIPE N2 PARA OUTRO LOCAL, PROMOVENDO SEU ISOLAMENTO

- **Fato:** Durante as observações, pudemos verificar a ocorrência de usuários acionando os analistas de acesso N2 presencialmente, por telefone e/ou *Communicator*.
- **Benefício:** Promover o isolamento ou mudança para outro local de acesso controlado, que permitirá aos analistas total atenção às filas de atendimento e aos chamados, evitando serem interrompidos para atendimentos ou solicitações pontuais. Além disso, a interação direta com os usuários pode promover ou facilitar solicitações indevidas, em detrimento às regras do processo.
- **Ações:** Mobilizar a equipe de analistas de acesso N2 para outro local com acesso controlado ou promover o isolamento das instalações (baias), evitando acesso direto de usuários aos mesmos. Neste contexto, cabe aos líderes da área avaliar e promover também o isolamento tecnológico, exemplos: não divulgação dos ramais e e-mails individuais, redirecionamento de ramal para o tronco-chave da área quando acionados diretamente, obrigatoriedade do envio de qualquer e-mail para usuários utilizando uma caixa de correio departamental, limitação de uso do *Communicator* somente para o grupo local ou no máximo para os analistas de tecnologia que possam auxiliar com alguma eventual dúvida, entre outros.

ID 05	IMPLANTAR A CADÊNCIA DE GESTÃO DIÁRIA (GEROT) E GESTÃO DOS PLANOS DE AÇÃO

- **Fato:** Durante as observações, pudemos verificar a necessidade de alinhamentos diários e efetivos entre as lideranças da área (líderes de GA e líderes de N1 e N2). Apesar de ocorrem alinhamentos sempre que necessário, não havia um ritual de gestão diário formalmente estabelecido com pauta definida e que promovesse correções de desvios, avaliação de ofensores e redirecionamentos mediante dificuldades ou impedimentos.
- **Benefício:** Maior sinergia entre os líderes, direcionamentos efetivos mediante dificuldades e correções de desvios.
- **Ações:** O método de Gestão da Rotina (GEROT) do Prof. Vicente Falconi é amplamente utilizado para gerenciamento de operações, como a Gestão de Acessos Lógicos. Uma vez estabelecido o método, deve ser realizada diariamente uma reunião com pauta padronizada, onde obrigatoriamente devem ser revisados os volumes e ofensores do dia anterior, levantadas as principais dificuldades e promovidas as atualizações dos Planos de Ação em andamento. Para o momento inicial de implantação, recomendamos que os membros participantes sejam: Leonardo Carmona, Eduardo Guastella, Juliano Panciera, Hugo Barros (Sonda IT) e remotamente Joice Candido (Sonda IT). Após o primeiro mês de execução, a lista de membros deve ser revisitada liberando do compromisso diário os gerentes sêniores, os quais passarão a participar de uma agenda semanal com a mesma pauta, incluindo a apresentação de resultados e estabelecimento de metas. Obs.: Como referência sobre o método citado é possível obter maiores informações através do livro "Gerenciamento da Rotina do Trabalho do dia-a-dia", de autoria de Vicente Falconi Campos.

ID 06	IMPLANTAR A GESTÃO DE CAUSA-RAIZ PARA TRATAR OS OFENSORES E *GAPS* DA GESTÃO DE ACESSOS

- **Fato:** Durante as observações, tomamos conhecimento sobre a lista de principais ofensores (categorias de chamados mais requisitadas pelos usuários) e percebemos que, para alguns, não havia clareza sobre o porquê de sua recorrência ou "destaque".
- **Benefício:** Os métodos de análise e resolução de problemas são amplamente utilizados para eliminação de situações recorrentes e falhas em áreas de operação, como a Gestão de Acessos Lógicos do BV. O objetivo de sua utilização é tratar com ações definitivas, como por exemplo automatizações, a lista de ofensores de chamados, questionando fatores como sazonalidades das demandas: *Por que tivemos x% de chamados sobre tal sistema? Isto representa uma sazonalidade, desvio ou algum evento de negócio ou de tecnologia?*
- **Ações:** Aplicar técnicas de análise e resolução de problemas, conduzindo sessões de investigação que envolvam os especialistas da área de Gestão de Acessos, seus analistas mais experientes e, se necessário, fornecedores, para identificar, analisar e eliminar as causas das recorrências. A identificação de novas automatizações também é resultado

deste processo de gestão. O Gerenciamento de Problemas (*Problem Management)* ou RCA (*Root Cause Analysis*) é a melhor prática comprovada para redução da quantidade de chamados recorrentes, amplamente documentado e esclarecido em *frameworks* como ITIL e COBIT. Neste contexto, um dos métodos mais utilizados são os "5 Porquês", que consistem no questionamento ao grupo do "por que" algo realmente aconteceu ou vem acontecendo, em uma sequência de até cinco vezes mediante a resposta anterior – feito isso, espera-se chegar à causa-raiz ou fato originador da situação em questão.

ID 07	LIBERAR O ACESSO PARA CONSULTA DE CHAMADOS PARA USUÁRIOS QUE SÃO PONTOS FOCAIS EM SUAS ÁREAS

- **Fato:** Durante as entrevistas ouvimos queixas de alguns usuários-chave de negócios que atuam como pontos focais em suas áreas e são constantemente escalados pelos colaboradores para apoio na resolução de chamados (chamados de solicitação de acessos). Estes usuários relataram suas dificuldades em obter *status* sobre os chamados abertos, pela existência de uma proibição na ferramenta CA *Service Desk* que impede um usuário de verificar chamados abertos por outros usuários, o que dificulta o trabalho destes pontos focais. Apesar da proibição, soubemos que a usuária-chave Camila Sato (Suporte Comercial do Varejo) conseguiu essa permissão junto ao time de Tecnologia. Atualmente, ela e sua equipe conseguem visualizar todos os chamados dos colaboradores do Varejo Comercial.
- **Benefício:** Redução da quantidade de chamados de "consulta", que é um dos *Top* Ofensores. Além disso, permitirá que os pontos focais consigam auxiliar efetivamente seus colegas de trabalho, obtendo os *status* e atuando sobre os chamados pendentes.
- **Ações:** Avaliar se não há restrições de auditoria ou *compliance* sobre este tema, solicitando posteriormente aos administradores da ferramenta CA *Service Desk* a liberação dos acessos para todos os pontos-focais das áreas de negócios (deve ser elaborada uma lista contendo todos os pontos focais, a qual precisa ser revisada periodicamente).

ID 08	ELABORAR E ACOMPANHAR NOVOS PLANOS DE AÇÃO RÁPIDOS

- **Fato:** Durante as entrevistas e observações, percebemos a dificuldade em manter e principalmente finalizar ações de melhorias, tais como a passagem da atividade de "manutenção de alçadas no *ERP*" para a área de Contas a Pagar, além de outras melhorias que precisam ser endereçadas.
- **Benefício:** Maior disciplina e foco na execução e finalização das ações de melhorias.
- **Ações:** Através do modelo de Plano de Ação Rápido criado em tempo de projeto e repassado ao coordenador da área de Gestão de Acessos do BV (Juliano Panciera), é possível detalhar novos planos de ação e promover, em conjunto com as reuniões

diárias de rotina, sua atualização e acompanhamento efetivo. Um exemplo de plano que precisa ser elaborado diz respeito à criação do "*Procedimento de Acesso ao Portal Jurídico*", conforme comentário da usuária-chave Alethea, que relatou sempre orientar os analistas de atendimento e de gestão de acessos sempre que necessita um novo acesso neste portal.

ID 09	AUTOMATIZAR A APROVAÇÃO DO GESTOR DE ACESSO

- **Fato:** Atualmente a ferramenta CA *Service Desk* já inclui automaticamente o Gestor do Solicitante como primeiro aprovador. O Gestor de Acesso (dono do sistema ou da informação) é inserido manualmente pelos analistas de acesso N1 com base nas informações da LPG (Lista de Proprietários e Gestores dos Sistemas). O administrador do CA *Service Desk*, Thiago Querino, já foi envolvido nesta iniciativa e informou que a ferramenta pode utilizar as informações que existem atualmente na LPG, pulicada oficialmente na página de Segurança da Informação na intranet. Apesar da viabilidade técnica, enfatizou a importância e recomendou a padronização da nomenclatura dos perfis de acesso que estão documentados na LPG, de forma que os usuários possam selecionar opções compreensíveis ao invés de siglas ou códigos de perfis ao solicitarem seus acessos
- **Benefício:** Eliminação de eventuais falhas operacionais como o apontamento incorreto do gestor de acesso, diminuição do tempo de atendimento em N1 e também eliminação do apontamento do gestor de acesso que esteja em período de férias.
- **Ações:** Padronizar a nomenclatura dos perfis de acesso que estão documentados na LPG, em conjunto com o time de Tecnologia da Informação.

ID 10	AUTOMATIZAR A COBRANÇA DOS CHAMADOS EM STATUS "PENDENTE CLIENTE"

- **Fato:** Atualmente os analistas de N1 efetuam cobranças aos usuários sobre os chamados que se encontram no status "Pendente Cliente" (chamado "parado" aguardando informações adicionais do usuário). Esta atividade demanda o deslocamento de um ou dois analistas (dependendo do volume) exclusivamente para realização das cobranças.
- **Benefício:** Maior disponibilidade de analistas para o atendimento telefônico e resolução de chamados em N1.
- **Ações:** Assim como já ocorre para as cobranças realizadas aos aprovadores durante os fluxos de aprovações, deve ser aberta uma demanda junto aos administradores da ferramenta CA *Service Desk* solicitando que os usuários sejam "cobrados" por e-mail, por um período a ser definido pela liderança de Gestão de Acessos. Após a realização das cobranças automatizadas, caso não ocorra nenhuma manifestação do usuário, o chamado deverá ser encerrado automaticamente.

4.2 Fase da Consolidação

A seguir, apresentamos as recomendações de ações de melhorias, encapsuladas na "Fase da Consolidação" que objetiva uma operação estável, com um *Backlog* gerenciado – reduzido a um nível aceitável.

As ações relacionadas à elaboração e implantação do Catálogo de Serviços foram previamente inseridas na "Fase de Estabilidade Operacional". Contudo, reconsideramos esta abordagem e inserimos as mesmas na "Fase de Consolidação", onde, após a eliminação do *Backlog*, será possível destinar o foco e os esforços necessários nestas atividades.

Nossas recomendações para esta fase são:

ID 11	**PROMOVER NOVA ANÁLISE DE DEMANDA E CAPACIDADE DE ATENDIMENTO (SIZING) APÓS A ELIMINAÇÃO DO *BACKLOG***

- **Fato:** Todas as equipes da Sonda IT e BV relacionadas à Gestão de Acessos estiveram focadas na meta proposta pelo *Information Security Officer*, Leonardo Carmona, sendo esta a eliminação completa do *Backlog* de chamados até o final de setembro.
- **Benefício:** Reavaliação do cenário pós-eliminação do *Backlog* promovendo melhor entendimento da capacidade de atendimento necessária para fazer frente a demanda prevista e futura nesta nova realidade.
- **Ações:** A Sonda IT, em conjunto com a liderança de Gestão de Acessos, deverá realizar o levantamento da demanda de chamados de acessos dos últimos doze meses, a fim de identificar eventuais sazonalidades, picos e médias de solicitações no período. Feito isso, deverá avaliar a produtividade média e estimar a capacidade de atendimento necessário (*sizing*) para manter o cenário pós-eliminação do *Backlog*, estimando a demanda futura sobre novas atividades relacionadas à gestão de acessos de outros sistemas que serão tombados para a área.

ID 12	**ELABORAR UM PROCEDIMENTO DE TRANSIÇÃO QUE CONTENHA TODOS OS PASSOS NECESSÁRIOS PARA ABSORÇÃO DA ADMINISTRAÇÃO DE USUÁRIOS DE NOVOS SISTEMAS PELA GESTÃO DE ACESSOS**

- **Fato:** Durante as análises e entrevistas, fomos informados sobre um universo de aproximadamente 40 (quarenta) ou 50 (cinquenta) sistemas que possuem sua administração de usuários sendo realizada por outra área fora da Gestão de Acessos. É de conhecimento que estas atividades serão migradas para que este controle seja realizado pela área de Gestão de Acessos do BV. Existe uma normativa que determina que estas atividades sejam realizadas pela equipe de Segurança da Informação (Gestão de Acessos), norma MNO_253 em sua cláusula 2.1.2. Esta norma também descreve a obrigatoriedade da execução de uma revisão de acessos pontual mediante a transferência da atividade de administração de usuários de uma outra área para a Gestão de Acessos.
- **Benefício:** A administração de usuários de sistemas centralizada na área correlata denota transparência, maior controle e minimiza desvios de processo.
- **Ações:** Deve ser elaborado um procedimento específico para a transferência ou transição da administração de acessos de sistemas para a área de Gestão de Acessos. Este processo deve considerar como atividades principais:
    a. Entendimento do escopo do sistema pela Gestão de Acessos;
    b. Identificação dos usuários-chave ou pontos-focais das áreas usuárias deste sistema para negociação de prazos de atendimento e posterior realização de reuniões para prestação de contas;
    c. Recebimento da documentação completa de todos os perfis de acesso do sistema;
    d. Análise da capacidade atual de atendimento (N1/N2) para absorção deste sistema entre Sonda IT e BV;
    e. Elaboração das categorias de chamados relacionadas a este sistema;
    f. Parametrização das categorias na ferramenta CA *Service Desk*;
    g. Realização de um treinamento sobre o módulo de administração de usuários aos analistas de N2/N3;
    h. Realização de um treinamento sobre os tipos de solicitações de acesso aos analistas de N1 para o correto direcionamento dos chamados;
    i. Reunião final para aceite da transferência da administração de usuários do sistema, com posterior documentação formal em ata.

ID 13	**PROMOVER A UTILIZAÇÃO DOS PERFIS POR FUNÇÃO (*RBAC*)**

- **Fato:** Durante as entrevistas com os usuários-chave dos negócios, obtivemos alguns relatos sobre seu entendimento e utilização efetiva das solicitações de acessos sobre os Perfis por Função (*RBAC*). Os usuários-chave que estiveram mais próximos do time de Gestão de Acessos durante o projeto de implantação deste modelo de solicitação, se demonstraram mais familiarizados com o assunto e comentaram que estavam

solicitando com mais frequência os acessos para os colaboradores de suas áreas através do *RBAC*. Já outros demonstraram interesse em conhecer melhor o assunto.

- **Benefício:** A maior utilização dos perfis por função beneficia os usuários no sentido de realizarem a abertura de apenas um único chamado para que sejam concedidos os acessos "padrão" para seu tipo de atividade/função. O sucesso desta iniciativa está diretamente relacionado à educação continuada dos usuários, dos donos dos perfis por função, dos analistas de gestão de acessos N1/N2 e também pela revisão periódica dos perfis por função para avaliação de sua aderência às necessidades das áreas.
- **Ações:** Promover *workshops*, palestras ou vídeo-treinamentos aos usuários, gerentes e lideranças das áreas de negócios, esclarecendo os benefícios e facilidades que o uso dos Perfis por Função resultará para suas operações. Incluir esta pauta nos comunicados oficiais da área e no programa de conscientização sobre segurança da informação, a exemplo da Semana de Segurança da Informação.

ID 14	**FORMALIZAR AS CATEGORIAS E PASSAR A EXIGIR ABERTURA DE CHAMADOS PARA AS SOLICITAÇÕES RECEBIDAS ATUALMENTE APENAS POR E-MAIL SEM REGISTRO NA FERRAMENTA CA *SERVICE DESK***

- **Fato:** Durante as análises e entrevistas, identificamos a existência de solicitações de acessos que são realizadas e solucionadas diretamente por e-mail, sem registro na ferramenta CA *Service Desk*, por exemplo: acesso a Sites Públicos / Promotoras.
- **Benefício:** Melhor visibilidade das demandas e controle efetivo sobre todas as solicitações de acessos em um único repositório de informação – a ferramenta CA *Service Desk*. Maior precisão para mensurar a real capacidade de atendimento vs. demandas da área de Gestão de Acessos.
- **Ações:** Promover reuniões entre os usuários-chave que estão relacionados a estas solicitações e respectivos analistas que provém os atendimentos (Nicolas do N2 e Klélder de Operações de SI). Em conjunto, identificar os tipos de solicitação, descrever as categorias de chamados adequadas e posteriormente solicitar aos administradores da ferramenta CA *Service Desk* sua parametrização. Elaborar um comunicado oficial para todos os usuários sobre a exigência de chamados sobre este escopo a partir da data combinada. Realizar alinhamento e eventual treinamento junto ao time de N1 para capacitá-los a absorver estas demandas. Avaliar oportunamente, outras demandas solicitadas sem o registro de chamados e repetir este procedimento novamente.

ID 15	**ELABORAR O CATÁLOGO DE SERVIÇOS DA GESTÃO DE ACESSOS LÓGICOS**

- **Fato:** Durante as análises, observações e entrevistas, pudemos constatar a dificuldade dos usuários em localizar a categoria de chamados mais adequada à sua solicitação. Usuários-chave nos relataram dificuldades dos colaboradores de seus times nestas situações, onde acabam solicitando ajuda ao usuário-chave ou analista de *Field Services*

disponível em seu andar. O catálogo atualmente estabelecido possui uma estrutura voltada para tecnologia/sistema (o primeiro nível de categorização possui itens como "*Hardware*" e "*Software*"), há duplicação de níveis, o mesmo serviço com nomenclaturas diferentes (exemplo: "liberar acesso" e "solicitar acesso"), além de ser demasiadamente extenso.

- **Benefício:** Elaboração de um catálogo com foco na "necessidade do usuário", ou visão de serviços orientada ao negócio, permitirá melhor compreensão das reais necessidades e solicitações dos usuários, incluindo a identificação precisa das informações mínimas para que os chamados sejam atendidos com maior prontidão, evitando desperdícios de tempo com a coleta de informações adicionais.
- **Ações:** Avaliar a estrutura atual do catálogo, mapeando todos os tipos de solicitações realizadas pelos usuários e identificando os atributos mínimos necessários para o atendimento (uma boa dica é consultar os *scripts* de atendimento do N1). Nossa recomendação se traduz na elaboração de um Catálogo de Serviços efetivamente focado no que realmente os usuários solicitam, tais como, "acesso a sistemas", "inclusão de usuários em grupo de e-mails", "acesso a um site específico", "acesso a e-mail externo (*webmail*)", **exemplo**:

1º nível de Categoria	2º nível de Categoria	3º nível de Categoria	Informações mínimas (campos selecionáveis obrigatórios)
Gestão de Acessos	Acesso a Recursos de Rede	*VPN*	Justificativa de necessidade, escopo de acesso, cargo
		Sites Específicos de Internet	URL do Site, Justificativa de necessidade
		E-mail Externo (webmail)	Justificativa de necessidade, cargo
		Diretórios de Rede	Diretório de Rede, Justificativa de necessidade
	Acesso a Sistemas	BV Financeira	Sigla/Nome amigável do Sistema (IC do Sistema), Perfis Desejados
		Banco Votorantim	Sigla/Nome amigável do Sistema (IC do Sistema), Perfis Desejados

  - No exemplo acima, na opção de "acesso a sistemas", o sistema-alvo da solicitação deveria ser apontado como um atributo obrigatório (IC - Item de Configuração) e não mais pertencer à estrutura/níveis de categorias, o que reduzirá drasticamente o volume total de possibilidades, facilitando ao usuário buscar a opção que deseja.
  - Obs.: A área de TI Sistemas está conduzindo, junto ao time de AMS da Sonda IT, a elaboração de um Catálogo em formato similar ao sugerido acima, apresentando uma visão por serviço. Neste sentido, recomendamos que a área de Gestão de Acessos busque o máximo de sinergia possível sobre este contexto, com a finalidade de maximizar a percepção de valor pelos usuários (novo catálogo de sustentação de sistemas e de gestão de acessos sendo elaborado e divulgado posteriormente em conjunto).
  - Adicionalmente a este relatório será entregue um modelo sugerido para o Catálogo de Serviços, utilizando dados reais da base disponível na ferramenta CA *Service Desk*.

ID 16	**IMPLANTAR O NOVO CATÁLOGO DE SERVIÇOS DA GESTÃO DE ACESSOS NA FERRAMENTA CA *SERVICE DESK***

- **Fato:** Após o mapeamento do novo Catálogo de Serviços, será necessário implantá-lo na ferramenta CA *Service Desk*. Em reunião com Thiago Querino, fomos informados sobre as funcionalidades que a ferramenta possui referente à exibição e obrigatoriedade de preenchimento de campos específicos dependendo da categoria de chamado selecionada. Isto se torna um fator preponderante na obtenção dos atributos mínimos para atendimento ao chamado, pois força os usuários a preencherem tais campos ou anexarem os documentos necessários, caso contrário o chamado não será aberto, evitando a abertura de chamados incompletos como ocorre atualmente.
- **Benefício:** Melhorar a experiência de abertura de chamados diretamente na ferramenta, minimizando a utilização de e-mails e ligações telefônicas ao *Service Desk*.
- **Ações:** Solicitar aos administradores da ferramenta CA *Service Desk* a implantação do novo Catálogo de Serviços de Gestão de Acessos, utilizando as funcionalidades de exibição e obrigatoriedade de preenchimento de determinados campos por categoria de chamado (informações já contidas no catálogo previamente elaborado).

ID 17	**DIVULGAR NOVO CATÁLOGO DE SERVIÇOS DE GESTÃO DE ACESSOS IMPLANTADO**

- **Fato:** Futuramente, após a implantação do novo Catálogo de Serviços da Gestão de Acessos, deverá ser realizada uma ação massiva e efetiva de comunicação aos usuários, esclarecendo os benefícios de sua utilização.
- **Benefício:** Ampliar a adesão e o uso efetivo do novo Catálogo de Serviços de Gestão de Acessos pelos usuários.
- **Ações:** Promover comunicações em massa para todos os usuários e prestadores de serviços do **Banco Votorantim** e suas empresas. Recomendamos que esta iniciativa de divulgação esteja alinhada ao trabalho que já vem sendo executado pela área de TI-Sistemas – lembrando que os usuários que utilizam os sistemas são únicos, tanto para Segurança da Informação quanto para Tecnologia. Quanto mais sinergia existir entre as ações de ambas as áreas, melhor será a percepção de valor pelos clientes internos e usuários.

ID 18	**REVISAR AS FILAS DE SUPORTE NA FERRAMENTA CA *SERVICE DESK***

- **Fato:** Atualmente a Gestão de Acessos trabalha com diversas filas de atendimento, sendo que algumas estão divididas pelo tipo de solicitação ou assunto, a saber:

- Filas N1: *"Help-Desk SI"*;
- Filas N2: *"SI", "SI - Perfil Por Funcao", "SI_Processo_AD", "SI RBAC", "SI_Banco de Dados", "SI_Financeira,"SI_Gestao de Perfis", "Sistema Global Acesso"*;
- Filas N3 (Especialistas): *"SI Especialistas";*
- Filas Operações de SI: *"SI_IDM" e "SI_Servicos".*

- **Benefício:** Facilitar o direcionamento de chamados e minimizar a possibilidade de encaminhamentos incorretos.
- **Ações:** Promover a revisão das filas de forma que reflitam os grupos ou níveis de suporte e não os assuntos a serem tratados, os quais devem ser diferenciados pelas categorias dos chamados (Catálogo de Serviços).

ID 19	**PROMOVER UMA REVISÃO COMPLETA DA DOCUMENTAÇÃO NORMATIVA RELACIONADA À GESTÃO DE ACESSOS**

- **Fato:** Conforme pudemos verificar em nossas análises, os documentos normativos relacionados ao processo de Gestão de Acessos Lógicos do **Banco Votorantim** estão extremamente aderentes aos requerimentos da Norma ABNT ISO/IEC 27002:2013. No entanto, é recomendável uma revisão completa dos mesmos, com a finalidade de atualizá-los sobre a realidade de operação atual (ex.: ferramenta ASK já substituída pelo CA *Service Desk* ou fluxogramas e procedimentos possivelmente defasados em relação às práticas atuais).
- **Benefício:** Manter os documentos normativos do processo de Gestão de Acessos Lógicos do **Banco Votorantim** sempre atualizados.
- **Ações:** Promover a atualização dos documentos frente às práticas estabelecidas e executadas. Neste contexto, avaliar a possibilidade de consolidação de alguns documentos em uma única Política de Gestão de Acessos, que poderá ser até um pouco mais extensa, mas permitirá aos usuários encontrarem todas as regras do processo em um único documento. Outro fator importante e decorrente da revisão completa é a e divulgação massiva da publicação das novas versões dos documentos, os quais devem ser de conhecimento geral dos clientes internos e usuários do processo de Gestão de Acessos Lógicos e podem até ser inseridos como obrigatórios na integração de novos colaboradores.

ID 20	**ELABORAR MATERIAIS DE TREINAMENTO SOBRE OS PRINCIPAIS SISTEMAS DO BANCO VOTORANTIM E SUA RESPECTIVA "LINGUAGEM COMUM" (SIGLAS DE SISTEMA), ALÉM DE OUTROS PROCEDIMENTOS E CONHECIMENTOS NECESSÁRIOS PELOS NÍVEIS INICIAIS DE SUPORTE**

- **Fato:** Durante as entrevistas com os usuários-chave dos negócios, tomamos conhecimento sobre algumas dificuldades enfrentadas relacionadas ao entendimento das solicitações pelos analistas do N1. Alguns usuários fizeram menção positiva à cordialidade e disponibilidade dos mesmos em ajudar, mas reforçaram que muitas

vezes estes analistas não conseguem compreender a "linguagem" utilizada pelos usuários. Além disso, fomos informados que um único treinamento "geral" ocorreu somente no início da operação.

- **Benefício:** Prover conhecimento sobre as siglas de sistemas, áreas de negócios e criticidades de forma a permitir melhor compreensão das solicitações e linguagem utilizadas pelos usuários durante os atendimentos.
- **Ações:** Conforme sugestão de papéis e responsabilidades já apresentada neste relatório, a elaboração dos materiais de treinamento deverá ser realizada pelos Especialistas de Gestão de Acessos e/ou Analistas de N3, de forma a documentarem os conhecimentos mais importantes. Deve ser considerada a elaboração destes materiais em formato de vídeo (*e-learning*), otimizando o tempo de todos os envolvidos, uma vez que vídeo-treinamentos podem ser reprisados em cadência a ser definida ou sempre que necessário.

ID 21	ESTABELECER PERIODICIDADE DE TREINAMENTOS E RECICLAGEM DE CONHECIMENTOS AOS NÍVEIS INICIAIS DE SUPORTE (N1 E N2)

- **Fato:** Durante as entrevistas junto aos analistas-chave de gestão de acessos, tanto de N1 quanto de N2, fomos informados sobre a necessidade de reciclagem de conhecimentos sobre os assuntos relacionados aos sistemas do banco, sobre os quais são realizadas as atividades de administração de usuários. Também tomamos conhecimento sobre a inexistência de uma periodicidade para realização dos mesmos.
- **Benefício:** Equalizar os conhecimentos sobre os módulos de administração de usuários e perfis dos sistemas do **Banco Votorantim**, permitindo o compartilhamento entre os analistas que detém conhecimentos específicos, transformando-os em "backups" uns dos outros.
- **Ações:** Estabelecer a periodicidade junto às lideranças da área e utilizar os materiais elaborados pelos especialistas e analistas de N3 para divulgação e compartilhamento destes conhecimentos entre os níveis de suporte iniciais.

ID 22	ESTABELECER INDICADORES DE PERFORMANCE (*KPI*) PREVIAMENTE DEFINIDOS PARA ACOMPANHAR A EVOLUÇÃO DO PROCESSO

- **Fato:** Durante as análises, identificamos a existência de um único indicador relacionado à Gestão de Acessos, quantidade de chamados abertos em *Backlog*, o qual era reportado diariamente e não possuía nenhuma meta associada.
- **Benefício:** Proporcionar à gerência sênior de Segurança da Informação, uma visão clara, objetiva e mensurável sobre o andamento da operação de Gestão de Acessos.
- **Ações:** Deliberar junto à gerência sênior de Segurança da Informação quais são os indicadores de performance (*KPI*) e as visões executivas/gerenciais mais adequadas para a gestão. O objetivo é elaborar um conjunto de indicadores que seja mais relevante

e significativo, incluindo as metas a serem perseguidas, as quais possam efetivamente originar os ciclos de melhoria contínua. Podemos citar alguns exemplos de indicadores que podem ser considerados:

- Quantidade de incidentes em que foi identificado algum acesso inapropriado ou indevido de usuários;
- Quantidade de pontos de auditoria que indicaram falhas de remoção ou revisão de acessos para usuários que mudaram de função ou foram desligados da empresa;
- Quantidade de chamados de *reset* ou desbloqueios de senhas;
- Quantidade de problemas/causas-raiz investigadas relativas a acessos indevidos ou não removidos de usuários;
- Quantidade de incidentes ocasionados por falhas ou erros operacionais de usuários que possuem privilégios administrativos;
- Percentual de requisições de acesso provisionadas dentro dos *SLAs* acordados com os negócios.

4.3 Fase da Nova Imagem da Gestão de Acessos

A seguir, apresentamos as recomendações de ações de melhorias, encapsuladas na "Fase da Nova Imagem da Gestão de Acessos" que objetiva uma aproximação junto às áreas usuárias no sentido de prestação de contas e principalmente a realização de automatizações de maior porte para aumentar o desempenho do processo.

Nossas recomendações para esta fase são:

ID 23	CAPACITAR OS ANALISTAS DE N3 PARA SE TORNAREM EFETIVAMENTE "PROVEDORES DE CONHECIMENTO" AOS NÍVEIS DE SUPORTE INICIAIS

- **Fato:** Nossa sugestão de revisão de papéis e responsabilidades sobre a função de "Analistas de Gestão de Acessos N3" recomendava que os mesmos possuíssem conhecimentos sólidos sobre os sistemas do banco, sistemas de gestão de acessos e também sobre as áreas críticas dos negócios que são sensíveis ao contexto de GA, além de facilidade e didática para transmitir conhecimentos através de documentação e treinamentos ministrados periodicamente aos times de N2 e N1. Segundo relatado pela liderança da área, os analistas possuem bons conhecimentos técnicos, mas não possuem muita didática para elaboração de documentação, por exemplo.
- **Benefício:** Proporcionar aos níveis de suporte iniciais maiores informações sobre a área e sistemas administrados, além de possibilitar que os analistas de N3 se tornem referência de conhecimentos.
- **Ações:** Apresentar aos analistas de N3 as responsabilidades sugeridas para a função e fomentar que os mesmos trabalhem no sentido de documentar ao máximo os conhecimentos em procedimentos e instruções de trabalho que possam ser utilizados pelos níveis de suporte iniciais (N1 e N2).

ID 24	AVALIAR OPORTUNAMENTE A USABILIDADE DOS MÓDULOS DE ADMINISTRAÇÃO DE USUÁRIOS DOS SISTEMAS MAIS CRÍTICOS E SOLICITAR AUTOMATIZAÇÕES E INTEGRAÇÕES PARA A ÁREA DE TECNOLOGIA DA INFORMAÇÃO

- **Fato:** Alguns analistas-chave nos reportaram a existência de módulos de administração de usuários que requerem diversas interações (cliques e telas que precisam navegar) para cada acesso efetivamente concedido, transferido ou revogado (exemplo: *ERP* do Varejo). Além disso, tomamos conhecimento sobre a necessidade de integrar alguns sistemas com a base autenticadora (AD/VF Acesso), tais como ERP, Crédito Web e URA (Código URA), uma vez que estes sistemas são parte da lista "*Top* Ofensora de autenticação por sistema". Conforme informações do Coordenador de Gestão de Acessos

há aproximadamente 13 (treze) sistemas críticos não integrados com AD/VF Acesso, que inclusive são escopo de auditorias.

- **Benefício:** [Automatizações] - Otimizar os tempos de atendimento das solicitações de acessos, incrementando a produtividade dos analistas e por consequência, elevando o nível de satisfação dos usuários, através das automatizações nos módulos de gestão de acessos dos sistemas mais críticos. [Integrações] – Mitigar os riscos e elevar o nível de segurança através das integrações de autenticação, evitando a não revogação de acessos, por exemplo. Além disso, através de autenticação única é possível reduzir as possibilidades de esquecimento de senhas que precisam ser memorizadas e protegidas pelos usuários, evitando a abertura de chamados relacionados a *resets*.
- **Ações:** [Automatizações] - promover estudo junto aos analistas-chave de gestão de acessos N2 e N3, sobre a quantidade de interações (cliques e telas que precisam navegar) para cada acesso que necessita ser provisionado nos sistemas mais críticos ou que possuem maior quantidade de chamados por mês. Depois desta etapa, listar os sistemas e classificar pela maior quantidade de interações necessárias. Apresentar este estudo para os responsáveis pela área de Sistemas de TI e solicitar demandas pela automatização destas atividades ou pela possibilidade de realização de cargas em lote. [Integrações] – promover estudos de viabilidade técnica e operacional junto aos responsáveis pela área de Sistemas de TI, com o objetivo de integrar os mecanismos de autenticação dos principais sistemas críticos que atualmente não possuem integração com as bases autenticadoras da organização (AD/VF Acesso).

ID 25	**SUBMETER O PROCESSO DE GESTÃO DE ACESSOS AO CICLO DE MELHORIA CONTÍNUA (PDCA)**

- **Fato:** Há procedimentos oficiais no repositório de documentação que possuem informações desatualizadas. Esta recomendação não se trata apenas de documentação, mas sim da revisão periódica do processo como um todo (fluxos, entradas, saídas, principais artefatos, indicadores, etc.).
- **Benefício:** Elevar o nível de maturidade do processo, otimizar rotinas e procedimentos operacionais, identificar e viabilizar automatizações e integrações sistêmicas.
- **Ações:** Por padrão, todo processo de gerenciamento deve ser submetido a ciclos periódicos de melhoria contínua, buscando a identificação de restrições, evoluções e novos requerimentos que se façam necessários. A Diretoria de Controles Internos e Riscos possui uma área de processos, a qual pode (e deve) apoiar as lideranças de Gestão de Acessos nestas revisões periódicas. Convém que o ciclo de revisão estabelecido seja, ao menos, anual.

ID	DEFINIR E DOCUMENTAR O PROCESSO DE GERENCIAMENTO DO NÍVEL DE SERVIÇO PARA SEGURANÇA DA INFORMAÇÃO E ESTABELECER PERIODICIDADE DE PRESTAÇÃO DE CONTAS JUNTO AOS CLIENTES INTERNOS (ÁREAS DE NEGÓCIOS)
26	

- **Fato:** Inexistência de um processo de Gerenciamento do Nível de Serviço no contexto da área de Segurança da Informação, fato evidenciado pela existência de um *SLA* (prazo de atendimento) de 48 horas úteis não formalizado, além de diversos "acordos" realizados pontualmente com determinadas áreas de negócios. Além disso, não existe uma cadência de prestação de contas com os clientes internos e usuários-chave das áreas de negócios.
- **Benefício:** Através deste processo, estabelecer e promover a proximidade e o relacionamento com as áreas de negócios, através do mapeamento de seus requerimentos (prazos de atendimento), acordos firmados e prestação de contas periódica.
- **Ações:** Como área provedora de serviços é importante que seja elaborado um processo de Gerenciamento do Nível de Serviço (*SLAs*) no contexto da Segurança da Informação. Este processo deve contemplar e promover iniciativas de relacionamento com os clientes internos, negociação e formalização de prazos de atendimento, ciclos de prestação de contas e garantia de acompanhamento da qualidade sobre o serviço de Gestão de Acessos fornecido aos negócios do **Banco Votorantim**. A área de Processos da Diretoria de Controles Internos e Riscos pode ser acionada para auxiliar no estabelecimento e documentação deste processo, amplamente descrito e difundido em *framework*s de mercado tais como ITIL e COBIT. Como atividades principais deste processo, devem ser consideradas:
    - Apuração dos tempos de atendimento atuais para cada área de negócio cliente do serviço de Gestão de Acessos Lógicos;
    - Negociação de prazos de atendimento (*SLAs*) factíveis para cada categoria de chamados, levando em consideração a capacidade de atendimento da área de Gestão de Acessos e os requerimentos de prazos das áreas de negócios;
    - Formalização (documento) dos prazos de atendimento acordados (*SLAs*);
    - Parametrização dos prazos de atendimento acordados (*SLAs*) nas respectivas categorias de chamados na ferramenta CA *Service Desk*;
    - Elaboração de um relatório customizado através da ferramenta de chamados CA *Service Desk*, contendo a visão mensal dos chamados solicitados e atendidos para as áreas de negócios;
    - Estabelecimento de uma cadência de prestação de contas junto aos usuários-chave e clientes internos dos negócios, utilizando o relatório para demonstração dos serviços prestados no período. Nossa sugestão é que a periodicidade seja mensal;
    - Revisão anual, ou em período definido, de todo o ciclo (apuração dos tempos de atendimento atuais, negociação dos prazos de atendimento, etc.).

ID 27	ELABORAR GUIA DE USO, PÁGINA DE SUPORTE E MATERIAL DE TREINAMENTO PARA OS CLIENTES INTERNOS E USUÁRIOS DO SERVIÇO DE GESTÃO DE ACESSOS LÓGICOS

- **Fato:** Usuários possuem dúvidas sobre "o que?" e "como?" solicitar seus pedidos de acessos. Necessário informá-los e instruí-los melhor sobre todos os aspectos referentes à Gestão de Acessos Lógicos.
- **Benefício:** Melhor compreensão do formato e dos tipos de solicitações que podem ser feitas para a Gestão de Acessos Lógicos pelos usuários. Além disso, evitará futuras ocorrências de chamados para esclarecimento de dúvidas e frustrações por falta de entendimentos.
- **Ações:** Uma vez implementado o novo Catálogo de Serviços na ferramenta CA *Service Desk*, convém que seja elaborado um Guia de Uso, digital e/ou impresso para facilitar a compreensão e localização das opções de solicitação de acessos pelos usuários. A elaboração de uma página de suporte específica sobre Gestão de Acessos na Intranet contendo informações, dicas, *SLAs* acordados, materiais de treinamento e demais informações relevantes ao assunto, também contribui no sentido de orientar melhor os usuários. Convém que os informativos e treinamentos sejam elaborados em formato de vídeo, tendo em vista a abrangência nacional dos negócios do **Banco Votorantim** e de suas empresas, uma vez que, através deste formato, os materiais podem ser acessados e facilmente compreendidos independentemente do local em que os usuários forem contratados para trabalhar. Também convém avaliar a possibilidade de inserção destes materiais no processo de integração de novos colaboradores.

4.4 Priorização das Recomendações

A seguir, apresentamos a nossa sugestão de priorização das recomendações propostas nos tópicos acima, utilizando o método **RAB**.

Este método, amplamente utilizado para priorização de ações de melhoria contínua, se baseia no resultado da multiplicação dos seguintes itens: **R**apidez de execução, **A**utonomia de execução e **B**enefício esperado.

Elaboramos a seguinte escala sob o contexto da Gestão de Acessos do **Banco Votorantim**:

Rapidez	Autonomia	Benefício
5 - Até um mês	**5** - Apenas área de Gestão de Acessos	**5** - Benefício operacional ALTO para a Gestão de Acessos (produtividade) e usuários (otimização no atendimento)
3 - Até três meses (pode necessitar projeto)	**3** - Gestão de Acessos, Tecnologia da Informação e/ou outras áreas de suporte	**3** - Benefício operacional MÉDIO para a Gestão de Acessos (produtividade) e usuários (otimização no atendimento)
1 - Mais de três meses (recomendável endereçar projeto)	**1** - Gestão de Acessos e Áreas de Negócios	**1** - Benefício operacional BAIXO para a Gestão de Acessos (produtividade) e usuários (otimização no atendimento)

Nossa sugestão de priorização das recomendações, dividida por fase.

FASE 1 – ESTABILIDADE OPERACIONAL

Fase	ID	Recomendação	Rapidez	Autonomia	Benefício	**Resultado/ Prioridade**
Fase 1	05	IMPLANTAR A CADÊNCIA DE GESTÃO DIÁRIA (GEROT) E GESTÃO DOS PLANOS DE AÇÃO	5	5	5	**125**
Fase 1	06	IMPLANTAR A GESTÃO DE CAUSA-RAIZ PARA TRATAR OS OFENSORES E *GAPs* DA GESTÃO DE ACESSOS	5	5	5	**125**

Fase	ID	Recomendação	Rapidez	Autonomia	Benefício	**Resultado/ Prioridade**
Fase 1	03	INSTALAR DOIS MONITORES PARA TODOS OS ANALISTAS DE ACESSO (N2 e N3)	5	3	5	**75**
Fase 1	07	LIBERAR O ACESSO PARA CONSULTA DE CHAMADOS PARA USUÁRIOS QUE SÃO PONTOS FOCAIS EM SUAS ÁREAS	5	3	5	**75**
Fase 1	08	ELABORAR E ACOMPANHAR NOVOS PLANOS DE AÇÃO RÁPIDOS	5	5	3	**75**
Fase 1	01	SANEAR O *BACKLOG* DE CHAMADOS	5	5	3	**75**
Fase 1	10	AUTOMATIZAR A COBRANÇA DOS CHAMADOS EM STATUS "PENDENTE CLIENTE"	3	3	5	**45**
Fase 1	04	MOBILIZAR EQUIPE N2 PARA OUTRO LOCAL, PROMOVENDO SEU ISOLAMENTO	3	3	3	**27**
Fase 1	02	IMPLANTAR GESTÃO À VISTA PARA O N2	3	3	3	**27**

Fase	ID	Recomendação	Rapidez	Autonomia	Benefício	**Resultado/ Prioridade**
Fase 1	09	AUTOMATIZAR A APROVAÇÃO DO GESTOR DE ACESSO	1	3	5	**15**

FASE 2 – CONSOLIDAÇÃO

Fase	ID	Recomendação	Rapidez	Autonomia	Benefício	**Resultado/ Prioridade**
Fase 2	11	PROMOVER NOVA ANÁLISE DE DEMANDA E CAPACIDADE DE ATENDIMENTO (SIZING) APÓS A ELIMINAÇÃO DO *BACKLOG*	5	5	5	**125**
Fase 2	12	ELABORAR UM PROCEDIMENTO DE TRANSIÇÃO QUE CONTENHA TODOS OS PASSOS NECESSÁRIOS PARA ABSORÇÃO DA ADMINISTRAÇÃO DE USUÁRIOS DE NOVOS SISTEMAS PELA GESTÃO DE ACESSOS	5	5	5	**125**
Fase 2	21	ESTABELECER PERIODICIDADE DE TREINAMENTOS E RECICLAGEM DE CONHECIMENTOS AOS NÍVEIS INICIAIS DE SUPORTE (N1 E N2)	5	5	5	**125**
Fase 2	18	REVISAR AS FILAS DE SUPORTE NA FERRAMENTA CA SERVICE DESK	5	5	3	**75**
Fase 2	15	ELABORAR O CATÁLOGO DE SERVIÇOS DA GESTÃO DE ACESSOS LÓGICOS	3	5	5	**75**

Fase	ID	Recomendação	Rapidez	Autonomia	Benefício	**Resultado/ Prioridade**
Fase 2	20	ELABORAR MATERIAIS DE TREINAMENTO SOBRE OS PRINCIPAIS SISTEMAS DO BANCO VOTORANTIM E SUA RESPECTIVA "LINGUAGEM COMUM" (SIGLAS DE SISTEMA), ALÉM DE OUTROS PROCEDIMENTOS E CONHECIMENTOS NECESSÁRIOS PELOS NÍVEIS INICIAIS DE SUPORTE	3	5	5	**75**
Fase 2	13	PROMOVER A UTILIZAÇÃO DOS PERFIS POR FUNÇÃO (*RBAC*)	3	3	5	**45**
Fase 2	16	IMPLANTAR O NOVO CATÁLOGO DE SERVIÇOS DA GESTÃO DE ACESSOS NA FERRAMENTA CA SERVICE DESK	3	3	5	**45**
Fase 2	17	DIVULGAR NOVO CATÁLOGO DE SERVIÇOS DE GESTÃO DE ACESSOS IMPLANTADO	3	3	5	**45**
Fase 2	22	ESTABELECER INDICADORES DE PERFORMANCE (*KPI*) PREVIAMENTE DEFINIDOS PARA ACOMPANHAR A EVOLUÇÃO DO PROCESSO	5	5	1	**25**
Fase 2	14	FORMALIZAR AS CATEGORIAS E PASSAR A EXIGIR ABERTURA DE CHAMADOS PARA AS SOLICITAÇÕES RECEBIDAS ATUALMENTE APENAS POR E-MAIL SEM REGISTRO NA FERRAMENTA CA SERVICE DESK	5	3	1	**15**
Fase 2	19	PROMOVER UMA REVISÃO COMPLETA DA DOCUMENTAÇÃO NORMATIVA RELACIONADA À GESTÃO DE ACESSOS	3	3	1	**9**

FASE 3 – NOVA IMAGEM DA GA

Fase	ID	Recomendação	Rapidez	Autonomia	Benefício	**Resultado/ Prioridade**
Fase 3	23	CAPACITAR OS ANALISTAS DE N3 PARA SE TORNAREM EFETIVAMENTE "PROVEDORES DE CONHECIMENTO" AOS NÍVEIS DE SUPORTE INICIAIS	5	5	5	**125**
Fase 3	26	DEFINIR E DOCUMENTAR O PROCESSO DE GERENCIAMENTO DO NÍVEL DE SERVIÇO PARA SEGURANÇA DA INFORMAÇÃO E ESTABELECER PERIODICIDADE DE PRESTAÇÃO DE CONTAS JUNTO AOS CLIENTES INTERNOS (ÁREAS DE NEGÓCIOS)	5	5	3	**75**
Fase 3	27	ELABORAR GUIA DE USO, PÁGINA DE SUPORTE E MATERIAL DE TREINAMENTO PARA OS CLIENTES INTERNOS E USUÁRIOS DO SERVIÇO DE GESTÃO DE ACESSOS LÓGICOS	3	3	5	**45**
Fase 3	24	AVALIAR OPORTUNAMENTE A USABILIDADE DOS MÓDULOS DE ADMINISTRAÇÃO DE USUÁRIOS DOS SISTEMAS MAIS CRÍTICOS E SOLICITAR AUTOMATIZAÇÕES E/OU INTEGRAÇÕES PARA A ÁREA DE TECNOLOGIA DA INFORMAÇÃO	1	3	5	**15**
Fase 3	25	SUBMETER O PROCESSO DE GESTÃO DE ACESSOS AO CICLO DE MELHORIA CONTÍNUA (PDCA)	1	3	5	**15**

5 CONSIDERAÇÕES FINAIS

A seguir, apresentamos uma visão final e imparcial sobre o cenário encontrado e perspectiva de futuro.

Durante os trabalhos de análises e entrevistas, pudemos constatar que a área de Gestão de Acessos Lógicos do **Banco Votorantim** possuía um viés altamente operacional, relacionado ao atendimento de chamados e eventuais incidentes relacionados ao assunto.

Esta característica se devia em grande parte ao enorme volume de chamados, muitos deles solicitando atividades menos complexas, tais como "*reset*s de senha", "desbloqueios de usuários" e até mesmo "consultas sobre a situação dos chamados já abertos", mas que, diante do volume total, representavam um percentual significativo.

As características deste cenário eram:

- O crescimento constante do *Backlog* e a dificuldade em eliminá-lo;
- O aumento da quantidade de chamados com prazo vencido;
- A sensação de incapacidade dos analistas de Gestão de Acessos para reverterem este cenário;
- O excesso de solicitações de priorização de atendimento;
- O excesso de tempo destinado ao tratamento dos efeitos e não das causas;
- A dificuldade em realizar planejamentos e gestão efetiva sobre este cenário;
- O aumento da frustração e dos impactos operacionais e financeiros dos clientes internos, decorrentes do não atendimento às solicitações de acesso em tempo hábil.

Apesar disso, logo no início do projeto pudemos encontrar um cenário em pequena evolução – o *Backlog* se encontrava na ordem de aproximadamente 1.000 chamados (considerando todos os níveis de suporte e os chamados "dentro e fora do prazo"), diante do volume aferido no início de 2015, quando o pico de aproximadamente 1.600 chamados em *Backlog* fora atingido.

Tal evolução de janeiro a julho/2015, na ordem de aproximadamente 37%, demonstrava que a área de Segurança da Informação e Sonda IT já estavam promovendo melhorias, mas com certa morosidade diante da situação de urgência.

O volume do *Backlog* no patamar de "milhar" continuava representando uma situação extremamente desconfortável para a área perante seus clientes internos e usuários, conforme depoimentos obtidos.

Neste contexto "crítico", a liderança do time vivia envolta em inúmeras solicitações de priorização de chamados e outras demandas não registradas, procurando atender prioritariamente os casos mais urgentes, relacionados às áreas de negócios mais sensíveis aos atrasos na provisão dos acessos.

Os esforços e o empenho de todos, tanto da Sonda IT quanto das lideranças da área de Segurança da Informação, estavam direcionados na busca por meios para reverter este cenário e chegaram a estabelecer um "Plano de Recuperação", fator motivador deste projeto de *Gap Analysis* e também da ampliação temporária do quadro de Analistas de N1 e N2, além da incorporação efetiva de um *Ticket Manager* e um Coordenador ao N2.

Com o objetivo principal pela resolução deste cenário, o time do Projeto de *Gap Analysis* antecipou as primeiras recomendações, as quais foram elaboradas sob a bandeira da Estabilidade Operacional, ou seja, prioritariamente recomendamos que fossem executadas ações de micro gerenciamento diário baseado na disciplina de Gestão da Rotina (método Vicente Falconi – anteriormente mencionado neste relatório), avaliação de causas-raiz dos principais ofensores, eliminação de barreiras operacionais e a conclusão de iniciativas que já estavam sendo trabalhadas, mas sem data de término efetiva. O pacote restante de recomendações foi inserido no contexto de evolução periódica, promovendo ganhos de maturidade.

Ao final de aproximadamente três meses de trabalho, podemos promover uma reflexão sobre a área de Gestão de Acessos do **Banco Votorantim**, a qual deve ser percebida como uma grande operação de suporte, que deve estar sempre apta a atender os mais de 4.000 colaboradores e as diversas EPS (incluindo seus inúmeros prestadores de serviço) trabalhando em benefício dos negócios de todo o Consolidado Econômico-Financeiro Votorantim, os quais, diariamente, sofrem uma série de mudanças, seja através de novas contratações, demissões, promoções ou transferências de área.

Neste contexto, a área de Gestão de Acessos representa um pilar de sustentação muito importante a todas as mudanças que este complexo "organismo" está suscetível, sendo o gatilho que viabiliza o início efetivo das atividades de qualquer colaborador.
Sob esta perspectiva e dimensão de volumes, todos os envolvidos na prestação do serviço de Gestão de Acessos Lógicos, sejam eles prestadores de serviço ou contratados efetivos da instituição, devem se enxergar como um único e coeso time, de forma que os clientes e usuários possam, ao longo dos próximos meses, perceber efetivamente as melhorias que já vem sendo promovidas e também aquelas que foram recomendadas neste relatório, uma vez implantadas.

Devemos entender como inadequada qualquer manifestação do tipo "o buraco está do seu lado do barco", tendo em vista que o "barco" da Gestão de Acessos é único e, se há um problema a ser resolvido, este pertence a todos os envolvidos.

Não há como deixar de lado ou minimizar a existência da relação hierárquica e contratual entre as partes envolvidas (ainda mais quando há níveis de serviço contratados), porém, a relação de confiança e parceria em prol dos clientes internos e usuários dos serviços de Gestão de Acessos precisa prevalecer sempre, em especial nos eventuais momentos de discórdia ou desavença.

Como visão para o futuro, a Gestão de Acessos deve buscar incansavelmente o maior nível de automatização e controle possível, de forma que possa estar cada vez mais próxima das áreas de Sistemas e principalmente das áreas de negócios, marcando presença e fazendo a diferença nos momentos de construção de novos sistemas ou grandes alterações naqueles já existentes.

Ao se aproximar das áreas de Sistemas, deverá apoiar e garantir que as implantações sejam realizadas com os perfis de acesso adequados ao uso pelas áreas usuárias e em concordância ao seu conjunto de normativas estabelecidas, como por exemplo, a Norma de Segregação de Funções de Segurança da Informação (MNO_671), que estabelece a obrigatoriedade da documentação completa dos perfis de acesso de cada sistema. Isto permitirá que a gestão efetiva dos acessos seja simplificada ou, que ao menos, possua todos os insumos necessários para que possa ser realizada de maneira satisfatória aos usuários deste serviço.

Ao se aproximar das áreas de negócios, deverá atuar como uma efetiva organização prestadora de serviços, reportando e demonstrando periodicamente os níveis de serviços atingidos para cada uma das áreas e interagindo sempre, no sentido de compreender as constantes alterações de requerimentos destes clientes sobre a prestação de serviços.

Além de buscar e implantar soluções seguras e inovadoras que permitam facilitar e gerar valor ao dia-a-dia das operações dos negócios (sob o contexto de Gestão de Acessos).

6 ANEXO A – MINI-CV DO TIME DO PROJETO

Eduardo Filho ***Information Security Officer***	
Atuação no Projeto	Gerente de Projeto
Experiência	Pós-graduado em Segurança da Informação e Bacharel em Gestão de Sistemas de Informação pela Universidade Paulista. Profissional com mais de 10 anos de experiência e atuação nas áreas de Segurança da Informação, Continuidade de Negócios, Auditoria, Gestão de Riscos e Governança de TI. Possuí amplos conhecimentos "*hands on implementation*" nos seguintes *frameworks* e *standards*: COBIT, ITIL, ISO27001, ISO27002, ISO22301, ISO31000, ISO38500, ISO20000, tendo atuado como Líder de Equipe, Gerente e Consultor Sr. em projetos de Gestão de Continuidade de Negócios, IAM – *Identity and Access Management*, implementação de ferramentas e processos, desenvolvimento de políticas e controles de SI/TI em empresas líderes de seus segmentos, tais como, Telefonica|Vivo, Terra, Grupo Pão de Açúcar, Fidelity, Galvão Engenharia, entre outras. É membro atuante da ISACA | Capítulo São Paulo, sendo um dos responsáveis pela tradução do *framework* COBIT 5 Implementação.
Certificações	ISO27001:2013 Lead Auditor | IRCA; ITIL V3; e COBIT.

Jorge Maluf ***IT Security & IT Governance Sr. Consultant***	
Atuação no Projeto	Consultor Executor
Experiência	Bacharel em Gestão de Sistemas de Informação pela Faculdade Impacta de Tecnologia e Engenheiro de Computação pela FASP, com mais de 13 anos de experiência em TI, sendo 8 anos em consultorias focadas em Governança, Gestão de TI e Segurança da Informação. Foi líder na área Governança de TI do Grupo Pão de Açúcar entre 2013 e 2015, tendo comandado diretamente as equipes de "Processos de TI", "Melhoria Contínua", "Performance de TI" e implantando processos, controles, ferramentas e métodos de gestão na companhia. Possui experiência comprovada como consultor e instrutor nas áreas de Gestão, Governança de TI e Segurança da Informação; Suporte a infraestrutura de Data Center em ambientes de missão crítica; Implantação de projetos de infraestrutura; Ger. de equipes de Suporte Técnico e Atendimento a Usuários. Em sua vivência já atendeu clientes como Polícia Militar do Estado de São Paulo, Banco Votorantim, Construtora OAS, Vivo, GVT, Natura, Grupo Pão de Açúcar, Tecsis, Cleartech, Edenred (Ticket), Itautec, entre outros.
Certificações	ITIL V3 Expert; ITIL V2 Service Manager; Information Security Foundation based on ISO 27002; COBIT e CGEIT – Certified in the Governance of Enterprise IT da ISACA.

7 ANEXO B – GLOSSÁRIO

A seguir, apresentamos os principais termos e acrônimos utilizados neste documento.

Termo ou Sigla	Descrição
ABNT	Acrônimo para Associação Brasileira de Normas Técnicas.
ACORDO DE NÍVEL DE SERVIÇOS (ANS)	Documento que formaliza o compromisso de entrega de um ou mais Serviços, estabelecendo direitos e obrigações do cliente e do fornecedor do serviço.
ACORDO DE NÍVEL OPERACIONAL (ANO)	Documento que formaliza o compromisso operacional de um fornecedor interno para suporte a um Serviço.
AS-IS	O mesmo que Cenário Atual.
ATIVIDADE	Um conjunto de ações definidas para atingir um resultado específico. Atividades são normalmente definidas como parte de Processos ou Planos e são documentadas em Procedimentos.
BACKLOG	Conjunto de chamados pendentes de atendimento com *SLA* violado.
BANCO DE DADOS DO GERENCIAMENTO DA CONFIGURAÇÃO (BDGC OU CMDB)	Repositório em que os IC são registrados e relacionados entre si, constituindo o modelo lógico da Infraestrutura e dos Serviços.
BV	Acrônimo para **Banco Votorantim**.
BYOD	Acrônimo para *Bring Your Own Device*.
CATÁLOGO DE SERVIÇOS	Relação de Serviços prestados pelo Provedor de Serviços para uma organização com os níveis e opções padrão documentados.
COBIT	Acrônimo para *Control Objectives for Information and related Technology* (*framework* para Gestão e Governança de TI).

Termo ou Sigla	Descrição
COMMUNICATOR	Aplicação de mensagens instantâneas utilizado internamente pelo **Banco Votorantim**.
DASHBOARD	Painel de gestão para monitoração de performance.
EFICÁCIA	Uma medida para identificar se os objetivos de um Processo, Serviço ou Atividade foram atingidos. Um Processo ou Atividade eficaz é aquele que atinge os seus objetivos acordados.
EFICIÊNCIA	Uma medida para identificar se a quantidade correta de recursos foi usada para entrega de um Processo, Serviço ou Atividade. Um processo eficiente alcança seus objetivos com a quantidade mínima necessária de tempo, dinheiro, pessoas ou outros Recursos.
E-LEARNING	Método utilizado para promover educação à distância.
EPS	Acrônimo para Empresa Prestadora de Serviços.
ERP	Acrônimo para *Enterprise Resource Planning* (sistema de informação que integra os dados e processos de uma organização).
ERRO	Disfunção que causa uma falha em um ou mais Itens de Configuração.
FIELD SERVICES	Equivalente a Equipe de Suporte em Campo.
FTE	Acrônimo para *Full-Time Equivalent* (medida para avaliação do comprometimento de horas úteis de trabalho de um colaborador em determinada atividade).
GA	Acrônimo para Gestão de Acessos Lógicos.
GERENCIAMENTO DA CONFIGURAÇÃO	Processo responsável por manter as informações sobre os Itens de Configuração necessários para entrega de Serviços, incluindo seus Relacionamentos. Esta informação é gerenciada durante todo o Ciclo de Vida do IC.
GERENCIAMENTO DE INCIDENTES	Processo responsável por gerenciar o Ciclo de Vida de todos os Incidentes. O principal objetivo do Gerenciamento de Incidentes é restabelecer os Serviços aos Usuários o mais rápido possível.

Termo ou Sigla	Descrição
GEROT	Acrônimo para Gerenciamento da Rotina (método de controle das atividades operacionais diárias criado por Vicente Falconi).
GMUD	Acrônimo para Gerenciamento de Mudanças (processo de gestão que formaliza alterações a serem realizadas em um ambiente computacional).
IDM	Acrônimo para *Identity Management* (gestão de identidades).
IMPACTO	"Impacto" é uma medida do grau de importância / relevância que a interrupção ou falha em potencial (Incidente), representa para os negócios. É muitas vezes medido pelo número de usuários afetados.
INCIDENTE	Qualquer evento que não faça parte da operação normal de um Serviço e que cause, ou possa causar, uma interrupção do serviço ou uma diminuição em sua qualidade.
ISO/IEC	Acrônimos para *International Organization for Standardization e International Electrotechnical Comission*.
ITEM DE CONFIGURAÇÃO (IC)	Qualquer componente técnico ou não, que relacionado a outros componentes constitui a Infraestrutura de um Serviço.
ITIL	Acrônimo para *Information Technology Infrastructure Library* (Conjunto de Melhores Práticas que orientam o Gerenciamento de Serviços de TI).
KPI	Acrônimo para *Key Performance Indicator* (indicadores de performance).
LOGIN	Identificador único de um usuário em um sistema ou recurso tecnológico.
LPG	Acrônimo para Lista de Proprietários e Gestores dos Sistemas (sigla utilizada pela área de Gestão de Acessos do **Banco Votorantim**).
MDS	Acrônimo para Metodologia de Desenvolvimento de Sistemas.
MELHOR PRÁTICA	Atividades ou Processos que comprovadamente obtiveram sucesso quando usado em várias Organizações. ITIL® é um exemplo de Melhor Prática.

Termo ou Sigla	Descrição
MUDANÇA	O acréscimo, modificação ou remoção, no status de um ou mais Itens de Configuração.
N1	Acrônimo para Nível 1 de Atendimento/Suporte.
N2	Acrônimo para Nível 2 de Atendimento/Suporte.
N3	Acrônimo para Nível 3 de Atendimento/Suporte.
NÍVEL DE SERVIÇO	Resultado relatado e medido em comparação com Metas de Nível de Serviço. O termo Nível de Serviço é, algumas vezes, usado como um termo informal para Meta de Nível de Serviço.
OLA (*OPERATIONAL LEVEL AGREEMENT*)	Verificar "Acordo de Nível Operacional (ANO)", neste Glossário.
PAYWARE	Nome de Sistema utilizado pelo **Banco Votorantim**.
PDCA	Acrônimo para *Plan-Do-Check-Act* (popularmente conhecido como Cliclo de Melhoria Contínua ou Ciclo PDCA é um método iterativo de gestão de quatro passos, utilizado para o controle e melhoria contínua de processos e produtos).
PROBLEMA	Registro elaborado para posterior investigação de causas-raiz de um ou mais Incidentes ou Requisições recorrentes.
PTA	Nome de Sistema utilizado pelo **Banco Votorantim**.
RAB	Acrônimo para Rapidez-Autonomia-Benefício (método de priorização utilizado para classificação de iniciativas de melhoria contínua).
REQUISITOS DE NÍVEL DE SERVIÇO (RNS)	Documento que apresenta as expectativas e necessidades do Cliente em relação a um Serviço.
RESET	O mesmo que reinicialização ou restauração.

Termo ou Sigla	Descrição
RISCO	Um evento possível que pode causar perdas ou danos, ou afetar a habilidade de atingir objetivos (fornecimento dos serviços). Um Risco é calculado pela Probabilidade de uma determinada falha ocorrer e pelo Impacto gerado caso a mesma venha a ocorrer efetivamente.
SAC	Acrônimo para Serviço de Atendimento ao Cliente.
SI	Acrônimo para Segurança da Informação.
SIZING	Ato ou processo de avaliação de dimensionamento de recursos humanos ou computacionais.
SLA (SERVICE LEVEL AGREEMENT)	Verificar "Acordo de Nível de Serviços (ANS)", neste Glossário.
SPONSOR	O mesmo que Patrocinador, ou seja, principal interessado na execução e no resultado de um projeto.
TI	Acrônimo para Tecnologia da Informação.
TOKEN	Método de Segurança que permite a geração de senhas ou códigos verificadores aleatórios, ampliando a proteção contra acessos não autorizados a um sistema de informação.
URGÊNCIA	"Urgência" é a medida sobre a "rapidez" necessária para resolução um Incidente. É muitas vezes uma medida derivada do Impacto, porém podem ser estabelecidos outros critérios, como relevância de receita financeira, por exemplo: quem gera maior receita, possui maior urgência de tratamento.
VPN	Acrônimo para *Virtual Private Network* (conexão estabelecida sobre uma infraestrutura pública ou compartilhada, baseada em tecnologias de tunelamento e criptografia para manter seguros os dados trafegados por usuários conectados remotamente).